

**INTELLIGENCE-
DRIVEN THREAT
HUNT PLAYBOOK
WITH THREAT
INTELLIGENCE
FEEDS EXAMPLE**

BY IZZMIER IZZUDDIN

Notepad++ Supply Chain Attack

Izzmier Cybersecurity Solution

Threat Intelligence Advisory

Advisory ID: SOC-INT-2026-02-NPP

Severity: High

Category: Supply Chain Compromise

Date Issued: February 2026

Threat Actor (Moderate Confidence): Lotus Blossom

1. Situation Overview

A targeted supply-chain compromise affected the Notepad++ update infrastructure between June–December 2025.

Attackers intercepted legitimate update traffic and delivered malicious NSIS installers through the official updater (WinGup / GUP.exe).

The campaign was espionage-driven, targeting:

- Government entities
- Financial institutions
- IT service providers
- Developers in Southeast Asia

The malware deployed includes a custom backdoor named Chrysalis, alongside Cobalt Strike and Metasploit tooling.

2. Affected Scope

Potentially Affected Assets

- Windows endpoints running Notepad++ with legacy WinGup updater
- Systems updated between June–October 2025
- Developer workstations
- IT admin systems

High-Risk Systems

- Privileged user endpoints
- Systems with internet-facing admin access

- Jump servers / management hosts

3. Threat Summary

Initial Access

- Supply chain compromise (MITRE T1195)
- Malicious NSIS installer delivered as update.exe

Execution & Persistence

- DLL sideloading via legitimate binary
- Reflective PE loading (memory execution)
- Windows service creation (T1543.003)
- Registry Run key fallback persistence

Command & Control

- Encrypted HTTPS over port 443
- API-style POST communication
- RC4-encrypted configuration

Post-Exploitation Capability

- Remote command execution (cmd.exe)
- File upload/download
- System reconnaissance (whoami, tasklist, netstat, systeminfo)
- Data exfiltration over C2 channel

4. Indicators of Suspicious Activity

File/Path Indicators

- %LOCALAPPDATA%\Temp\ns.tmp
- %APPDATA%\ProShow\
- %APPDATA%\Adobe\Scripts\
- %APPDATA%\Bluetooth\

Suspicious Processes

- update.exe (unexpected NSIS installer behavior)
- log.dll loaded by non-standard executable
- Renamed legitimate binaries loading unsigned DLLs

LOLBin Monitoring

Alert on unusual use of:

- cmd.exe
- netstat.exe
- tasklist.exe
- systeminfo.exe

Network Indicators

- Outbound HTTPS to unknown domains
- API-style POST requests with encrypted payload
- DNS/HTTP(S) to:
 - temp.sh
 - cdncheck.it
 - safe-dns.it
 - self-dns.it

5. Required SOC Actions

Immediate (Within 24–48 Hours)

1. Identify systems that updated Notepad++ between June–October 2025.
2. Isolate suspicious endpoints.
3. Perform memory analysis where possible.
4. Block known malicious domains at firewall and proxy.
5. Force manual update to Notepad++ v8.9.1 or later from verified source.
6. Temporarily restrict execution of WinGup (GUP.exe) via application control.

Short-Term (Within 7 Days)

- Conduct enterprise-wide threat hunting for:
 - NSIS installer artifacts
 - DLL sideloading behavior
 - Reflective memory execution patterns
- Review service creation logs for abnormal services.
- Check registry Run keys for anomalies.
- Rotate credentials for:
 - Privileged users
 - Service accounts
 - Developer accounts

Medium-Term Controls

- Enforce digital signature verification for software updates.
- Deploy WDAC/AppLocker for execution control.
- Block execution from:
 - %APPDATA%
 - %LOCALAPPDATA%
 - %TEMP%
- Enable DLL Safe Search Mode.
- Strengthen egress filtering policies.

6. Threat Hunting Queries (Focus Areas)

EDR

- Reflective code loading events
- Unbacked memory execution
- Suspicious DLL loaded from user directory

Windows Logs

- Event ID 7045 (Service creation)
- Event ID 4688 (Process creation – unusual parent-child chain)
- Registry modification events

Network Logs

- HTTPS POST traffic with consistent beacon intervals
- Long-lived TLS sessions to uncommon domains

7. Risk Assessment

Likelihood: Moderate (Selective targeting)

Impact: High (Credential theft, lateral movement, data exfiltration)

Business Risk: Significant for financial and regulated entities

This attack bypasses traditional perimeter defenses due to abuse of trusted software update workflows.

8. Escalation Criteria

Escalate to Incident Response Lead if:

- Cobalt Strike beacon behavior observed
- Suspicious service creation confirmed
- Encrypted outbound traffic to known IOC domains

- Evidence of credential dumping or lateral movement

9. Strategic SOC Lessons

- Supply-chain compromise remains a Tier-1 risk vector.
- Trusted software does not equal trusted update path.
- Behavioral detection must complement signature validation.
- Developer and admin systems require stricter egress and execution controls.

PLAYBOOK 1: NOTEPAD++ SUPPLY CHAIN UPDATE COMPROMISE (CHRYSLIS / DLL SIDELOADING CHAIN)

1. Purpose

This playbook describes, step-by-step, how a SOC performs an intelligence-driven threat hunt when a TI feed reports a selective supply-chain compromise of a trusted software update mechanism (Notepad++ legacy updater WinGup/GUP.exe delivering a malicious NSIS “update.exe”, followed by DLL sideloading to load a malicious log.dll, leading to a custom backdoor “Chrysalis” and possible Cobalt Strike/Metasploit usage).

The playbook covers start-to-end actions:

- intake and scoping
- retrospective hunting and validation
- containment and eradication
- recovery and hardening
- reporting and detection uplift

2. When to Trigger This Playbook

Trigger when at least one is true:

1. Your TI provider or vendor report states Notepad++ update infrastructure compromise and selective redirection of update traffic during a defined window (example in feed: June–Oct 2025 update window with activity up to December).
2. Any internal telemetry shows:
 - GUP.exe retrieving an unexpected “update.exe”
 - installer behaviour from user-writable locations
 - DLL sideloading signs (legit EXE loading a DLL from non-standard directory)
 - suspicious API-like HTTPS POST traffic to unknown hosts
3. You discover endpoints that performed Notepad++ updates within the affected window.

3. Scope Definition (What You Are Hunting For)

From the TI feed, the typical chain you should assume:

Stage A: Supply-chain delivery via updater

- Legit Notepad++ updater (WinGup/GUP.exe) fetches “update.exe” that is actually a malicious NSIS installer.

Stage B: Dropper and sideload

- NSIS drops/executes a renamed legitimate binary (example in feed: a Bitdefender submission wizard binary renamed as BluetoothService.exe) which sideloads a malicious log.dll.

Stage C: In-memory execution and backdoor

- Encrypted/decrypted shellcode, reflective loading, API hashing, HTTPS C2 with API-like endpoints (blends with normal web).

Stage D: Post-exploitation

- Recon commands (whoami, tasklist, systeminfo, netstat -ano) and possible offensive frameworks (Cobalt Strike, Metasploit).

4. Roles and Ownership

- Threat Intel / SOC Lead: confirms relevance to your environment, sets hunt objective and time window.
- L2 Hunter: runs queries, builds timelines, validates signals.
- L3 / IR Lead: decides containment actions, coordinates forensics and eradication.
- Endpoint Team: isolation, reimaging, application control, software inventory.
- Network Team: egress filtering, DNS blocks, proxy controls.
- Platform Team: SIEM rules, EDR detection policies, allowlisting.

5. Inputs Required (Before You Start)

Collect these first:

1. Software inventory: endpoints with Notepad++ installed; version; last update date.
2. Telemetry availability (at minimum):
 - EDR process + file events
 - DNS logs
 - proxy / secure web gateway logs

- Windows Security logs (4688 if enabled, 7045, 4657 if available)
- 3. The TI indicators and behaviour from the feed:
 - suspicious paths and artefacts (example: %LOCALAPPDATA%\Temp*.tmp)
 - suspicious directories (example: %APPDATA%\ProShow\, %APPDATA%\Adobe\Scripts\, %APPDATA%\Bluetooth\)
 - suspicious domains (example in feed recommendations: temp.sh, cdncheck.it, safe-dns.it, self-dns.it)

6. Step-by-Step SOP (Start to End)

Step 1: TI Intake and Local Relevance Check

Objective: decide if this is relevant and define your hunt window.

Actions:

1. Extract from TI:
 - affected timeframe
 - execution chain summary (updater → NSIS → sideload → backdoor)
 - key artefacts (files, directories, domains)
2. Determine local exposure:
 - Do you have Notepad++ deployed in the bank (dev machines, admin workstations)?
 - Are endpoints allowed to update directly from the internet?
 - Do you have legacy WinGup/GUP.exe behaviour (no strict signature verification)?

Output:

- Hunt window (example: 2025-06-01 to 2025-10-31 for update events, plus follow-on activity up to now).
- Target population (all endpoints with Notepad++ installed; prioritise dev/admin endpoints).

Step 2: Build Target Endpoint List (Asset Scoping)

Objective: reduce noise and hunt efficiently.

Actions:

1. Pull endpoint list:
 - Installed application = Notepad++
 - Last execution times for notepad++.exe and GUP.exe

2. Prioritise:

- developer workstations
- privileged users
- servers where admins might have used Notepad++
- any endpoint that updated within TI window

Output:

- “Hunt cohort” list (hostname, user, dept, IP, risk tier).

Step 3: Hunt Track 1: Updater Network Behaviour (Ingress Tool Transfer)

Objective: identify suspicious update retrieval and redirection patterns.

What to hunt:

- GUP.exe or Notepad++ reaching out to unusual hosts
- downloads named update.exe not from expected domains
- sudden change of update URL path patterns
- direct download of NSIS-like installer from non-standard host

Example query logic (generic SIEM):

- Where process = GUP.exe AND http_method in (GET, POST) AND url contains “update” AND destination_domain not in allowlist
- Where file_download_name = “update.exe” AND parent_process = GUP.exe

Decision:

- If you find any endpoint with suspicious “update.exe” download, move it to “Suspect” list and proceed to Track 2 immediately.

Step 4: Hunt Track 2: Endpoint Artefacts (NSIS, Sideload, Hidden Directories)

Objective: confirm installer execution and sideload behaviour.

What to hunt (high-signal):

1. File creation:

- %LOCALAPPDATA%\Temp\ns.tmp (NSIS temp artefact)

2. Suspicious directories:

- %APPDATA%\ProShow\
- %APPDATA%\Adobe\Scripts\
- %APPDATA%\Bluetooth\

3. Process patterns:
 - notepad++.exe → GUP.exe → update.exe
 - update.exe spawning renamed signed binary (example: BluetoothService.exe)
4. DLL sideload indicators:
 - BluetoothService.exe (or any legitimate EXE) loading log.dll from a user-writable directory rather than its normal install path

Decision:

- If DLL sideload pattern is observed, treat as high-confidence compromise and move to containment steps (Step 7) while continuing evidence capture.

Step 5: Hunt Track 3: Discovery and Recon Commands

Objective: catch post-compromise activity.

What to hunt:

- suspicious sequences of built-in commands, especially shortly after installer execution:
 - whoami
 - tasklist
 - systeminfo
 - netstat -ano

Query approach:

- On suspect endpoints, list processes executed within 30 minutes after the “update.exe” execution.
- Look for cmd/powershell launching those recon commands.

Decision:

- If recon commands appear, escalate severity and expand scope: check lateral movement attempts from that host.

Step 6: Hunt Track 4: C2 Patterns (HTTPS API-Like POST)

Objective: identify stealthy outbound communications.

What to hunt:

- outbound HTTPS to rare domains/IPs with:

- frequent POST requests
 - consistent small payload sizes
 - user-agent patterns mimicking common software
- connections over 443 from endpoints that usually do not initiate outbound to unknown hosts

Also hunt for the domains mentioned in TI recommendations (example): temp.sh, cdncheck.it, safe-dns.it, self-dns.it

Decision:

- If any suspect endpoint shows outbound API-like POST traffic to unknown host, treat as active backdoor communication and proceed to containment immediately.

Step 7: Containment (Do This Immediately When High-Confidence Signals Found)

Containment goal: stop attacker control, prevent lateral movement, preserve evidence.

Actions (in this order):

1. Isolate endpoint via EDR network containment (do not power off unless instructed by forensics).
2. Block outbound to known malicious domains and any newly discovered C2 domains at DNS/proxy/firewall.
3. Disable or restrict Notepad++ updater component execution (GUP.exe) via application control until verified safe versions are deployed (as suggested in the feed recommendations).
4. If privileged user machine:
 - immediately revoke sessions / tokens (where applicable)
 - reset credentials (Step 9)

Evidence capture:

- collect EDR triage package:
 - process tree
 - loaded modules
 - network connections
 - file hashes and paths for update.exe, BluetoothService.exe, log.dll, NSIS temp artefacts

Step 8: Eradication

Goal: remove persistence and malware artefacts.

Actions:

1. Remove malicious files and directories discovered:
 - suspicious %APPDATA% subfolders from TI list
 - ns.tmp and related NSIS artifacts (after evidence capture)
2. Check persistence:
 - Windows services created around compromise window (service creation)
 - Registry run keys as fallback persistence
3. If backdoor presence is suspected (reflective loading, obfuscated payloads, injection):
 - recommend reimage / rebuild for high assurance (banking environment best practice)
4. Patch and remediate exposure:
 - force manual update to a secure Notepad++ version from verified source (feed mentions manual update to safe version and improved verification controls).

Step 9: Credential and Access Hygiene (Financial Sector Requirement)

Because the TI feed indicates long dwell time and credential compromise risk, treat compromised endpoints as credential exposure risk.

Actions:

1. Force password resets:
 - affected user accounts
 - local admin accounts used on endpoint
2. Rotate:
 - service accounts used on endpoint
 - API keys, tokens, SSH keys (if dev workstation)
3. Invalidate cached auth where feasible.
4. Review privileged group membership changes around compromise window.

Step 10: Recovery and Hardening

Goal: prevent recurrence of the same supply-chain vector.

Controls to implement:

1. Update integrity controls:
 - enforce certificate and signature validation for update workflows
 - reject unsigned or externally hosted installers
 - use signed update manifests if available
2. Execution control:

- block executable launch from user-writable directories:
 - %APPDATA%, %LOCALAPPDATA%, %TEMP%
- 3. DLL sideload prevention:
 - tighten DLL loading rules where feasible
 - alert when signed executables load DLLs from user-writable paths
- 4. Network controls:
 - egress filtering from developer/admin endpoints
 - alert on suspicious API-style POST requests to unknown domains

Step 11: Reporting (What to Produce)

Deliverables:

1. Hunt report (one pager + appendix):
 - TI summary and why relevant
 - scope and endpoints reviewed
 - findings (confirmed / suspicious / clean)
 - evidence snapshots (process tree, network events, hashes)
 - containment and eradication actions taken
2. Risk statement:
 - impact narrative aligned to financial sector (trusted update abuse, silent access, long-term espionage risk)
3. Lessons learned and detection gaps.

Step 12: Detection Engineering (Turn Hunt Into Permanent Detections)

Create/modify detections:

1. GUP.exe downloading and executing update.exe from non-allowlisted domain
2. NSIS temp artefact creation:
 - %LOCALAPPDATA%\Temp\ns.tmp
3. Signed EXE sideloading suspicious DLL:
 - BluetoothService.exe loading log.dll from user-writable directory
4. Recon command burst after installer execution:
 - whoami, tasklist, systeminfo, netstat -ano
5. HTTPS C2 pattern:
 - frequent POST to rare domain + small payload + long-lived sessions

7. End-to-End Worked Example With Simulated Logs

Scenario Summary

- Developer workstation ABC-DEV-014 has Notepad++ installed.
- During the TI window, it runs Notepad++ update.

- Updater retrieves malicious NSIS “update.exe”.
- NSIS drops BluetoothService.exe and log.dll into %APPDATA%\Bluetooth\.
- BluetoothService.exe sideloads log.dll.
- Host runs recon commands and starts outbound HTTPS POST to a rare domain.

Below is a small, realistic simulated timeline you can use to train analysts.

A) Proxy / Web Gateway Logs (Download)

timestamp	host	user	process	method	url	dest_domain
2025-09-18T10:14:22Z	ABC-DEV-014	ABC\hafiz	GUP.exe	GET	/npp/update/v8.7.4/update.exe	cdncheck.it
				ALLOW	512	1832942
2025-09-18T10:14:24Z	ABC-DEV-014	ABC\hafiz	GUP.exe	GET	/npp/update/v8.7.4/update.exe.sig	cdncheck.it
				ALLOW	480	1024

High-signal reasoning:

- GUP.exe contacting a domain not in your official Notepad++ allowlist.
- Downloaded object named update.exe.

B) EDR Process Creation (Execution Chain)

timestamp	host	user	parent_process	process	cmdline
2025-09-18T10:14:35Z	ABC-DEV-014	ABC\hafiz	notepad++.exe	GUP.exe	"C:\Program Files\Notepad++\updater\GUP.exe" -options
2025-09-18T10:14:49Z	ABC-DEV-014	ABC\hafiz	GUP.exe	update.exe	"C:\Users\hafiz\AppData\Local\Temp\update.exe" /S
2025-09-18T10:15:03Z	ABC-DEV-014	ABC\hafiz	update.exe	BluetoothService.exe	"C:\Users\hafiz\AppData\Roaming\Bluetooth\BluetoothService.exe"

High-signal reasoning:

- Updater spawning an installer from a user-writable temp location.
- Installer spawning a “service-like” binary from %APPDATA%.

C) EDR File Events (Drop + NSIS Artefacts)

timestamp	host	user	event_type	file_path
2025-09-18T10:14:50Z	ABC-DEV-014	ABC\hafiz	FILE_CREATE	C:\Users\hafiz\AppData\Local\Temp\ns.tmp
2025-09-18T10:15:01Z	ABC-DEV-014	ABC\hafiz	FILE_CREATE	C:\Users\hafiz\AppData\Roaming\Bluetooth\BluetoothService.exe

2025-09-18T10:15:02Z ABC-DEV-014 ABC\hafiz FILE_CREATE
C:\Users\hafiz\AppData\Roaming\Bluetooth\log.dll

High-signal reasoning:

- ns.tmp matches NSIS installer behaviour.
- log.dll appears alongside a “trusted-looking” EXE in a user-writable folder.

D) Module Load (DLL Sideload Evidence)

timestamp	host	process	image_path	loaded_module
2025-09-18T10:15:04Z	ABC-DEV-014	BluetoothService.exe	C:\Users\hafiz\AppData\Roaming\Bluetooth\BluetoothService.exe	C:\Users\hafiz\AppData\Roaming\Bluetooth\log.dll

High-signal reasoning:

- Signed/legitimate-style EXE loading a DLL from the same non-standard directory is classic sideload behaviour.

E) Command Execution (Recon Burst)

timestamp	host	parent_process	process	cmdline
2025-09-18T10:16:10Z	ABC-DEV-014	BluetoothService.exe	cmd.exe	/c whoami
2025-09-18T10:16:13Z	ABC-DEV-014	BluetoothService.exe	cmd.exe	/c systeminfo
2025-09-18T10:16:18Z	ABC-DEV-014	BluetoothService.exe	cmd.exe	/c tasklist
2025-09-18T10:16:25Z	ABC-DEV-014	BluetoothService.exe	cmd.exe	/c netstat -ano

F) Network (C2-Like HTTPS POST)

timestamp	host	process	dest_ip	dest_domain	dest_port	method	uri_path	bytes_out	bytes_in
2025-09-18T10:17:02Z	ABC-DEV-014	BluetoothService.exe	203.0.113.77	safe-dns.it	443	POST	/api/v1/check	842	610
2025-09-18T10:18:02Z	ABC-DEV-014	BluetoothService.exe	203.0.113.77	safe-dns.it	443	POST	/api/v1/check	838	605
2025-09-18T10:19:02Z	ABC-DEV-014	BluetoothService.exe	203.0.113.77	safe-dns.it	443	POST	/api/v1/check	845	612

High-signal reasoning:

- Repeated POST pattern to an unknown domain with consistent payload sizes suggests beaconing.

8. Final Decision Logic (How Analyst Concludes)

If you have:

- suspicious updater download of update.exe plus
- NSIS artefact ns.tmp plus
- sideload pattern (BluetoothService.exe loads log.dll from user folder) plus
- outbound HTTPS POST beacon pattern

Then outcome should be:

- Confirmed compromise (high confidence)
- Immediate containment and credential rotation
- Forensic triage + likely rebuild
- Detection rule creation and egress blocks

WinRAR Zero-Day Multiple Groups Now Exploiting CVE-2025-8088

Izzmier Cybersecurity Solution

Threat Intelligence Advisory

Advisory ID: SOC-INT-2026-02-WINRAR

Severity: Critical

Category: Zero-Day Exploitation

Date Issued: February 2026

Vulnerability: CVE-2025-8088

Threat Actors: Multiple (State-sponsored & Financially Motivated)

1. Situation Overview

A critical WinRAR zero-day vulnerability (CVE-2025-8088) is being actively exploited by multiple threat groups.

The vulnerability allows malicious RAR archives to bypass extraction safeguards and drop malicious files into sensitive directories (e.g., Windows Startup folder) via path traversal and ADS (Alternate Data Stream) abuse.

Exploitation has been observed across:

- Russia-nexus APT groups
- China-nexus actors
- Financially motivated cybercrime groups

This is an actively exploited vulnerability in the wild.

2. Attack Summary

Initial Access Vector

- Spearphishing emails delivering malicious RAR attachments
- RAR archives containing weaponized .lnk files
- Path traversal extraction into:

`%AppData%\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\`

Execution Flow (Observed Variants)

Variant 1 – Mythic Agent

RAR → LNK → msedge.exe hijack → malicious DLL sideload → C2 beacon

Variant 2 – SnipBot

RAR → DisplaySettings.lnk → ApbxHelper.exe → downloads payload → C2

Variant 3 – MeltingClaw

RAR → Settings.lnk → Complaint.exe → install_module_x64.dll → beacon

3. Observed Threat Actors

Russia-Nexus Actors

- UNC4895 (RomCom)
- APT44 (FrozenBarents)
- TEMP.Armageddon
- Turla

China-Nexus Actor

- PRC-based actor delivering POISONIVY malware

Financially Motivated Groups

- RAT distribution campaigns
- Credential stealers
- Chrome banking extension malware
- Telegram-based C2 backdoors

Exploitation activity observed through January 2026.

4. Affected Systems

- WinRAR versions prior to 7.13
- Systems using UnRAR.dll (embedded integrations)
- Endpoints that:
 - Allow RAR extraction without restriction
 - Permit execution from Startup folder
 - Lack EDR or file integrity monitoring

5. Indicators of Suspicious Activity

File System Indicators

- Unexpected .lnk files in Startup folder
- Malicious DLLs in:
 - %TEMP%
 - %LOCALAPPDATA%
- ADS-based file creation
- Extraction errors referencing malformed paths

Registry Indicators

- Unauthorized persistence entries
- New Startup folder registry modifications

Process Indicators

- msedge.exe loading suspicious DLL
- Execution of:
 - ApbxHelper.exe
 - Complaint.exe
 - install_module_x64.dll

Network Indicators

- Beacon traffic to unknown domains
- Telegram-based C2 communications
- Encrypted outbound traffic to rare domains

6. Required SOC Actions

Immediate (Within 24 Hours)

1. Force update to WinRAR 7.13 or later (manual update required).
2. Identify systems running vulnerable versions.
3. Hunt for .lnk files in Startup directories.
4. Block suspicious outbound domains at perimeter.
5. Quarantine suspicious RAR attachments at mail gateway.

Short-Term (Within 7 Days)

- Deploy detection rules for:
 - ADS file creation
 - LNK execution from archive extraction
 - DLL sideloading from user directories
- Review email logs for RAR-based phishing attempts.
- Enable attachment sandboxing if not already deployed.

- Conduct enterprise-wide threat hunt for:
 - Startup persistence artifacts
 - Suspicious DLL loads by signed binaries

Medium-Term Hardening

- Block execution from Startup folder unless signed.
- Restrict archive extraction to controlled directories.
- Enforce MFA for SSH and remote services.
- Implement strict internal segmentation.
- Enforce SPF, DKIM, DMARC.
- Disable browser password storage on high-risk systems.

7. Threat Hunting Focus

Windows Event Logs

- Event ID 4688 (Process creation)
- Event ID 7045 (Service creation)
- Registry modification events

EDR Queries

- LNK execution with parent winrar.exe
- Execution from Startup folder shortly after archive extraction
- DLL loaded from non-standard path by signed binary

Network Monitoring

- Outbound HTTPS with beacon-like intervals
- Telegram API traffic from endpoints
- Unknown domains resolving shortly after archive extraction

8. Risk Assessment

Likelihood: High (Active exploitation by multiple groups)

Impact: Critical (Persistence, C2, credential theft, RAT deployment)

Business Risk: Severe if phishing bypasses detection

This vulnerability enables direct persistence via Startup folder injection, making it highly dangerous for enterprise environments.

9. Escalation Criteria

Escalate to Incident Response Lead immediately if:

- LNK file found in Startup folder from RAR extraction
- Confirmed DLL sideloading
- Telegram-based C2 traffic observed
- RAT or stealer payload identified
- Credential harvesting suspected

10. Strategic SOC Lessons

- Archive extraction controls must be treated as execution vectors.
- Email-based RAR attachments are high-risk.
- Zero-days are now exploited simultaneously by both APT and cybercrime groups.
- Endpoint execution control and behavior-based detection are critical layers of defense.

PLAYBOOK 2: WINRAR ZERO-DAY EXPLOITATION (CVE-2025-8088) – LNK/STARTUP PATH ABUSE, ADS, PAYLOAD DELIVERY

1. Purpose

This playbook describes, step-by-step, how a SOC performs an intelligence-driven threat hunt when a TI feed reports active exploitation of a WinRAR zero-day (CVE-2025-8088) used by multiple threat groups to deliver payloads via malicious RAR archives, often through spearphishing. The reported behaviours include malicious archive extraction effects (notably suspicious LNK creation and Startup folder abuse, including ADS-based paths), DLL/EXE payload execution chains, registry persistence and outbound C2 communications.

The playbook covers start-to-end actions:

- intake and scoping
- retrospective hunting and validation
- containment and eradication
- recovery and hardening
- reporting and detection uplift

2. When to Trigger This Playbook

Trigger when at least one is true:

1. Your TI provider reports active exploitation of CVE-2025-8088 or multiple groups targeting organisations using malicious RAR archives (including job-application themed lures).
2. Any internal telemetry shows:
 - Users receiving external emails with RAR attachments, followed by extraction activity and/or WinRAR error messages during unpacking (as shown in the feed's screenshots).
 - Creation of unexpected .lnk files in Startup folders shortly after RAR extraction, including suspicious path patterns consistent with traversal/ADS-based behaviour.
 - Malicious DLLs appearing in %TEMP% / %LOCALAPPDATA% and being loaded by signed/legitimate processes.
 - Unauthorised registry entries related to persistence.
3. You discover endpoints running WinRAR below the recommended patched version (7.13 or later), noting WinRAR does not auto-update per the feed recommendation.

3. Scope Definition (What You Are Hunting For)

From the TI feed, assume these common patterns:

Stage A: Initial access via spearphishing

- RAR attachments sent to targeted users (example lures in the feed show “job application / resume” themes).

Stage B: Exploit effect during extraction

- Malicious archive content results in creation of .lnk in Startup folder, sometimes leveraging path manipulation patterns described in the “Vulnerability and Exploit Mechanism” figure.

Stage C: Execution chain variants

The feed illustrates multiple chains, for example:

- A RAR delivers an LNK that triggers a chain involving msedge.exe loading a DLL and beaconing to a C2 domain.
- A RAR delivers an LNK that executes an EXE which then downloads from a C2 domain.
- Another variant executes an EXE, downloads a DLL, then beacons to C2.

Stage D: Persistence and follow-on activity

- Registry persistence and/or Startup LNK persistence, plus outbound encrypted traffic and anomalous C2 patterns.

4. Roles and Ownership

- Threat Intel / SOC Lead: confirms relevance, sets objective, defines hunt window and priority user groups.
- L2 Hunter: runs queries, builds timelines, validates signals and expands scope.
- L3 / IR Lead: directs containment, forensics triage, eradication decisions, rebuild requirements.
- Endpoint Team: patch validation, isolation, reimage, application control, file quarantine.
- Email Team: message trace, sandboxing, attachment policy tuning, SPF/DKIM/DMARC control enforcement.
- Network Team: DNS/proxy egress blocks, segmentation checks, C2 suppression.
- Platform Team: SIEM rules, EDR policy, file integrity monitoring, detection pack deployment.

5. Inputs Required (Before You Start)

Collect these first:

1. Asset inventory
 - endpoints with WinRAR installed; version; install date; last execution time
 - endpoints using UnRAR.dll (and any software relying on it), as the feed recommends updating dependent software too
2. Telemetry availability (minimum)
 - EDR process + file events (incl. module loads if possible)
 - Email gateway logs (attachment metadata + sandbox results)
 - DNS + proxy/SWG logs
 - Windows Security logs (4688 if enabled; Startup folder writes; registry changes where available)
3. Threat intel extraction from the feed
 - patch guidance: update to WinRAR 7.13 or later, because WinRAR does not auto-update
 - detection focus: ADS-based file creation, malicious DLLs in %TEMP%/LOCALAPPDATA%, unauthorised registry persistence
 - behavioural monitoring: suspicious .lnk created in Startup, suspicious extraction/startup behaviour

6. Step-by-Step SOP (Start to End)

Step 1: TI Intake and Local Relevance Check

Objective: confirm relevance and define hunt boundaries.

Actions:

1. Extract from TI:
 - urgency and patch recommendation (WinRAR 7.13+) and note lack of auto-update
 - high-risk behaviours to monitor (ADS creation, DLLs in temp paths, registry persistence, Startup LNK)
 - initial access pattern (spearphishing with RAR attachments)
2. Determine local exposure:
 - do you permit RAR attachments inbound?
 - do you have HR/recruitment mailboxes that routinely open CVs/resumes?
 - do you have WinRAR deployed broadly on endpoints, including admin/dev machines?
 - do you have attachment sandboxing and executable-in-archive blocking?

Output:

- Hunt window (for example: last 90 days, plus targeted lookback to when the TI states exploitation is ongoing)
- Target population (high priority: HR/recruitment, executive assistants, IT admins, developer workstations)

Step 2: Build Target Endpoint and User Cohort (Asset Scoping)

Objective: reduce noise and focus on likely victims.

Actions:

1. Pull endpoint list:
 - WinRAR installed (version < 7.13 = highest priority to hunt)
 - endpoints that executed WinRAR.exe / rar.exe / unrar.exe recently
2. Pull user cohort:
 - users who received external emails with RAR attachments

- users who extracted RAR archives shortly after receipt

Output:

- “Hunt cohort” list (hostname, user, dept, email, IP, WinRAR version, risk tier)

Step 3: Hunt Track 1: Email and Attachment-to-Execution Correlation

Objective: confirm the initial access chain (email → attachment → extraction → execution).

What to hunt:

- inbound emails with .rar attachments, especially spearphishing patterns shown in the feed
- attachment opened followed by extraction activity and/or WinRAR errors (feed shows extraction errors and warnings during unpacking)

Example correlation logic (generic):

- email_gateway where attachment_ext = rar AND sender_external = true
- within 0–60 minutes: endpoint process = WinRAR.exe OR file writes under Downloads/Desktop/Temp consistent with extraction

Decision:

- if an email with rar attachment correlates to extraction on endpoint, move endpoint to Suspect and proceed to Track 2.

Step 4: Hunt Track 2: Startup Folder LNK and Extraction Abuse

Objective: detect the core exploit effect / persistence pattern.

What to hunt (high signal):

- creation of .lnk in:
 - C:\Users\<user>\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\
 - C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\
- suspicious .lnk creation occurring within minutes of WinRAR.exe extraction activity
- suspicious path patterns consistent with the exploit mechanism figure (Startup placement and unusual filename patterns)
- ADS-related file creation signals (explicitly recommended as a detection focus in the feed)

Decision:

- If .lnk is created in Startup and correlates to RAR extraction, treat as high-confidence compromise and proceed to containment while continuing evidence capture.

Step 5: Hunt Track 3: Payload Execution Chain (EXE/DLL load)

Objective: identify the execution chain after the LNK triggers.

What to hunt:

- .lnk execution launching:
 - a browser-like process (msedge.exe) that loads a DLL from unusual locations (one chain in the feed shows a msedge EXE/DLL relationship leading to C2)
 - unusual helper EXEs followed by downloads (multiple chains in the feed show LNK → EXE → download / beacon)
- malicious DLL appearance in %TEMP% / %LOCALAPPDATA% and being loaded by a process, as recommended in detection guidance

Decision:

- If a legitimate process loads a DLL from %TEMP%/ %LOCALAPPDATA% after LNK execution, escalate severity and expand scope to other recipients of the same RAR attachment.

Step 6: Hunt Track 4: Persistence (Registry + Startup)

Objective: detect survival mechanisms.

What to hunt:

- unauthorised registry entries for persistence (explicitly recommended by the feed)
- repeat execution at logon/startup triggered by Startup folder LNK

Decision:

- If persistence is confirmed, treat as active infection and execute containment immediately.

Step 7: Hunt Track 5: C2 and Anomalous Outbound Traffic

Objective: identify beaconing and remote control.

What to hunt:

- outbound encrypted traffic and anomalous C2 patterns (explicitly recommended monitoring focus)
- connections to rare domains following the execution chain (the feed's execution-chain diagrams show beaconing-to-C2 behaviour)
- repeated HTTPS POST/GET patterns at intervals, small and consistent payload sizes

Decision:

- If beaconing is observed, treat as active compromise and proceed to containment immediately.

Step 8: Containment (Immediate Actions When High-Confidence Signals Found)

Containment goal: stop execution, prevent lateral movement, preserve evidence.

Actions (in this order):

1. Isolate endpoint via EDR containment (do not power off unless forensics instructs).
2. Block outbound to newly identified suspicious domains/IPs at DNS/proxy/firewall.
3. Quarantine malicious artifacts:
 - the RAR archive
 - Startup .lnk
 - any payload EXE/DLL in %TEMP%/LOCALAPPDATA%
4. Email containment:
 - purge/recall the malicious email from mailboxes (where controls permit)
 - block sender/domain and attachment hash
5. If privileged endpoint/user:
 - revoke sessions/tokens where applicable
 - move to Step 10 credential actions urgently

Evidence capture:

- EDR triage package: process tree, module loads, file hashes/paths, network connections, persistence keys
- email headers + attachment hash + sandbox report

Step 9: Eradication

Goal: remove persistence and malicious artifacts.

Actions:

1. Remove Startup folder .lnk and any related dropped files after evidence capture.
2. Remove malicious DLLs/EXEs from %TEMP%/LOCALAPPDATA% (feed emphasises monitoring these locations).
3. Remove unauthorised registry persistence entries (feed calls out persistence registry entries).
4. If uncertainty remains (possible multi-stage payload, stealthy agent):
 - rebuild/reimage endpoint for high assurance (financial-sector best practice)

Step 10: Credential and Access Hygiene

Because the feed recommends credential protection measures and highlights multi-actor exploitation, assume credential theft risk on affected endpoints.

Actions:

1. Reset user credentials for affected accounts.
2. Rotate privileged credentials used on affected hosts.
3. Invalidate sessions on cloud/SaaS where possible.
4. Review privileged group membership and suspicious logons during the incident window.
5. Apply hardening recommendations where feasible (credential guard, vaulting, reduced browser password saving) as part of remediation plan.

Step 11: Recovery and Hardening

Goal: prevent recurrence and close control gaps.

Actions aligned to the feed:

1. Patch urgently:
 - update WinRAR to 7.13 or later (WinRAR does not auto-update)
 - update dependent components (UnRAR.dll / portable UnRAR / source code)
2. Email security controls:
 - attachment sandboxing for RAR archives
 - block executables inside compressed archives from external senders
 - enforce SPF/DKIM/DMARC

3. Endpoint monitoring:

- detect ADS-based file creation
- detect malicious DLLs in %TEMP%/LOCALAPPDATA%
- detect unauthorised registry persistence
- monitor unexpected .lnk files created in Startup folders

4. Network controls:

- monitor unusual SSH tunnelling / encrypted outbound / anomalous C2 patterns
- block unused ports and tighten segmentation

Step 12: Reporting and Detection Uplift

Deliverables:

1. Hunt report:

- TI summary, scope, endpoints reviewed
- confirmed/suspicious/clean findings
- evidence snapshots (email trace, file events, persistence, network)
- actions taken and residual risk

2. Detection engineering:

- Rule 1: External email with RAR attachment → extraction event → Startup .lnk creation
- Rule 2: Startup .lnk created by WinRAR.exe or immediately after WinRAR.exe runs
- Rule 3: DLL load from %TEMP%/LOCALAPPDATA% by legitimate process
- Rule 4: ADS-based file creation events on endpoints (per feed)
- Rule 5: Registry run key creation by suspicious process chain (per feed)
- Rule 6: Rare domain beaconing after LNK execution chain

7. End-to-End Worked Example With Simulated Logs (Training Timeline)

Scenario summary:

- A recruiter user receives an external job application email with a RAR attachment.
 - User opens and extracts using WinRAR (unpatched).
 - Extraction results in a Startup LNK being created.
 - LNK triggers execution chain that loads a DLL from user-writable location.
 - Host begins outbound C2-like traffic.
- This aligns to the spearphishing + LNK/Startup + execution chain behaviour described in the feed's figures and recommendations.

A) Email Gateway Logs (Inbound RAR)

timestamp	msg_id	recipient	sender	subject
2026-02-04T02:11:10Z	MSG-883120	ABC\recruit.hr01	pepita.cordero@external.tld	Application for Job Openings - July JobDocs_July2025.rar
DELIVERED				
2026-02-04T02:12:01Z	MSG-883120	ABC\recruit.hr01	pepita.cordero@external.tld	Application for Job Openings - July JobDocs_July2025.rar (sandbox) -
SUSPICIOUS				

B) Endpoint Process Creation (Open and Extract)

timestamp	host	user	parent_process	process	cmdline
2026-02-04T02:14:07Z	ABC-HR-022	ABC\recruit.hr01	explorer.exe	WinRAR.exe	"C:\Program Files\WinRAR\WinRAR.exe" "C:\Users\...\Downloads\JobDocs_July2025.rar"
2026-02-04T02:14:22Z	ABC-HR-022	ABC\recruit.hr01	WinRAR.exe	explorer.exe	"C:\Windows\explorer.exe" "C:\Users\...\Downloads\JobDocs_July2025\"

C) Endpoint File Events (Suspicious Startup LNK + Temp DLL)

timestamp	host	user	event_type	file_path
2026-02-04T02:14:25Z	ABC-HR-022	ABC\recruit.hr01	FILE_CREATE	C:\Users\recruit.hr01\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\Updater.lnk
2026-02-04T02:14:27Z	ABC-HR-022	ABC\recruit.hr01	FILE_CREATE	C:\Users\recruit.hr01\AppData\Local\Temp\msedge.dll
2026-02-04T02:14:28Z	ABC-HR-022	ABC\recruit.hr01	FILE_CREATE	C:\Users\recruit.hr01\AppData\Local\Temp\msedge.exe

Why this is high-signal:

- Startup .lnk created immediately after extraction (feed recommends monitoring unexpected Startup LNK creation).
- DLL/EXE appearing in %TEMP%/LOCALAPPDATA% is directly called out as a monitoring focus.

D) Module Load (DLL Loaded by Process)

timestamp	host	process	image_path	loaded_module
2026-02-04T02:15:03Z	ABC-HR-022	msedge.exe	C:\Users\recruit.hr01\AppData\Local\Temp\msedge.exe	C:\Users\recruit.hr01\AppData\Local\Temp\msedge.dll

E) Registry Persistence (Example)

timestamp	host	user	event_type	reg_path
2026-02-04T02:15:30Z	ABC-HR-022	ABC\recruit.hr01	REG_VALUE_SET	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\Updater = "C:\Users\...\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\Updater.lnk"

Why this matters:

- The feed explicitly recommends monitoring unauthorised registry entries for persistence.

F) Proxy / DNS Logs (C2 Pattern)

timestamp	host	user	process	dest_domain	dest_ip	dest_port
2026-02-04T02:16:10Z	ABC-HR-022	ABC\recruit.hr01	msedge.exe	srlaptop.com	203.0.113.40	443
2026-02-04T02:17:10Z	ABC-HR-022	ABC\recruit.hr01	msedge.exe	srlaptop.com	203.0.113.40	443
2026-02-04T02:18:10Z	ABC-HR-022	ABC\recruit.hr01	msedge.exe	srlaptop.com	203.0.113.40	443

method	uri	bytes_out	bytes_in	action
POST	/checkin	820	602	ALLOW
POST	/checkin	818	598	ALLOW
POST	/checkin	823	605	ALLOW

Why this is high-signal:

- periodic outbound encrypted traffic consistent with “anomalous C2 patterns” mentioned in recommendations and execution-chain diagrams.

8. Final Decision Logic (How Analyst Concludes)

If you have:

- external email with RAR attachment plus
- WinRAR extraction activity plus
- Startup .lnk creation shortly after extraction (and/or ADS indicators) plus
- payload DLL/EXE in %TEMP%/LOCALAPPDATA% being loaded plus
- outbound beaconing pattern

Then outcome:

- Confirmed compromise (high confidence)
- Immediate containment and credential actions
- Forensic triage and likely rebuild for assurance

- Detection rule creation (email-to-extraction correlation + Startup LNK + temp DLL load + anomalous C2)
- Rapid patch rollout to WinRAR 7.13+ and dependent UnRAR components as per TI guidance

React2Shell

Izzmier Cybersecurity Solution

Threat Intelligence Advisory

Advisory ID: SOC-INT-2026-02-REACT2SHELL

Severity: Critical

Category: Web Application RCE (Internet-Facing)

Date Issued: February 2026

Vulnerability: React2Shell – CVE-2025-55182 (CVSS 10.0)

Threat Actors (Observed): Earth Lamia, Jackpot Panda, botnets, cryptomining groups, opportunistic scanners

1. Situation Overview

React2Shell is a critical unauthenticated Remote Code Execution (RCE) vulnerability affecting React Server Components (RSC) and frameworks implementing the RSC “Flight” protocol, most notably Next.js. The flaw is caused by unsafe deserialization in the react-server package, allowing arbitrary server-side JavaScript execution via a single malicious HTTP POST request.

Active exploitation is confirmed in the wild, with rapid escalation including scanning, mass exploitation, credential theft attempts, malware deployment and cryptomining. CVE-2025-55182 is also noted as included in CISA’s Known Exploited Vulnerabilities (KEV) catalogue (urgent remediation expectation).

2. Affected Scope

Vulnerable Components (Confirm in SBOM/SCA)

- React RSC versions 19.0.0 – 19.2.0
 - react-server-dom-webpack, react-server-dom-parcel, react-server-dom-turbopack
- Next.js (App Router):
 - 14.3.0-canary.77
 - early 15.x
 - 16.x before 16.0.7
- Other RSC adopters: Vite RSC plugin, Parcel, RedwoodJS, Waku, React Router RSC preview

High-Risk Targets

- Internet-facing Next.js applications using App Router / RSC
- Cloud-hosted rendering nodes (container/serverless/edge) with broad outbound access
- CI/CD-integrated environments containing build secrets and tokens

3. Attack Vector (What to Expect)

One-Request RCE

- Attacker sends a crafted HTTP POST to an RSC endpoint using the Flight protocol.
- Unsafe deserialization triggers execution of attacker-controlled JavaScript on the server.

Typical Post-Exploitation Activities Observed

- “Proof-of-execution” commands (cheap validation commands)
- Payload retrieval and staging:
 - Sliver C2
 - Mirai variants
 - XMRig cryptominer
 - credential harvesters / SSRF tooling
- Cloud credential theft:
 - .env files, env vars
 - cloud metadata service queries (AWS/GCP/Azure)

4. Observed Threat Actors

- Earth Lamia (aka BypassBoss): China-nexus actor exploiting public-facing apps for initial access; known for rapid vulnerability exploitation and modular tooling.
- Jackpot Panda: China-nexus intrusion set with history of targeted operations, including supply-chain-style activity.
- Also observed: botnets, cryptomining groups, opportunistic scanners performing automated exploitation.

5. Detection & Monitoring Guidance

Identify Likely Exposed Endpoints (Hunting Targets)

Look for access patterns to RSC-related paths such as:

- /react
- /_flight
- /_rsc
- Next.js internal RPC paths generated dynamically

Web / WAF Signals (High Priority)

- Anomalous POST requests to RSC endpoints
- Unexpected Content-Type and high-entropy bodies
- Headers / fields linked to Flight protocol exploitation attempts (e.g., unusual “action” style indicators)

Host / Runtime Signals

- Suspicious child process execution from Node runtime
- Outbound calls from rendering hosts to unknown destinations
- Sudden CPU spikes / resource usage consistent with mining (XMRig)

Cloud Signals

- Requests to metadata services from app containers:
 - AWS 169.254.169.254/latest/meta-data/
 - Azure /metadata/instance?...
 - GCP /computeMetadata/v1/

6. Required SOC Actions

Immediate (0–24 Hours)

1. Inventory & exposure check: Identify all apps using RSC / Next.js App Router; validate versions via SBOM/SCA.
2. Patch now:
 - Upgrade React RSC to 19.2.1+ (safe deserialization patch).
 - Upgrade Next.js to 16.0.7+ (and align dependencies).
3. Apply temporary mitigations where patching is delayed:
 - Restrict public access to RSC endpoints (VPN/Zero Trust/IP allowlists/reverse proxy).
 - Apply WAF rules targeting abnormal Flight protocol payloads.
4. Increase monitoring on:
 - POST traffic to RSC endpoints
 - suspicious outbound connections from app servers
 - metadata service access attempts

Short-Term (24–72 Hours)

- Rebuild and redeploy the full application stack (containers/serverless/edge/static assets) to remove potential tampering.
- Rotate secrets if exploitation is suspected:
 - IAM keys, DB creds, OAuth/SSO secrets, JWT keys, third-party API tokens

- Block metadata access at network level for workloads that do not require it.

Medium-Term Hardening

- Restrict or prevent child process execution (where feasible)
- Tight egress filtering: only required outbound domains
- Immutable / read-only runtime filesystems; file integrity monitoring (Falco/CSM equivalents)
- Move secrets out of env vars into secret managers (Vault/Secrets Manager/KeyVault)

7. Impact Assessment (Why This Matters)

Potential outcomes include:

- Full server RCE and total application compromise
- Theft of secrets (API keys, DB passwords, JWT signing keys, OAuth secrets)
- Cloud account takeover via stolen credentials
- Lateral movement into microservices and CI/CD pipelines
- Persistent implants, web shells, scheduled tasks
- Cryptomining (XMRig) and cost impact
- Potential ransomware deployment and service disruption

8. Escalation Criteria

Escalate to Incident Response Lead immediately if any of the following are observed:

- Exploit-like POST requests to RSC endpoints followed by command execution indicators
- Unexpected access to cloud metadata endpoints from workloads
- New outbound C2-like connections from rendering/app servers
- Signs of miner deployment (high CPU + suspicious processes)
- Evidence of secret access (reads of .env, config maps, secret mounts)

PLAYBOOK 3: REACT2SHELL (CVE-2025-55182) – UNAUTHENTICATED RCE VIA REACT SERVER COMPONENTS FLIGHT PROTOCOL (NEXT.JS / RSC ECOSYSTEM)

1. Purpose

This playbook describes, step-by-step, how a SOC performs an intelligence-driven threat hunt when a TI feed reports active exploitation of React2Shell (CVE-2025-55182), a critical unauthenticated RCE affecting React Server Components (RSC) and frameworks

implementing the RSC “Flight” protocol, most notably Next.js. The root cause is unsafe deserialization in the react-server package, enabling server-side JavaScript execution through a single malicious HTTP request.

The playbook covers start-to-end actions:

- intake and scoping
- retrospective hunting and validation
- containment and eradication
- recovery and hardening
- reporting and detection uplift

2. When to Trigger This Playbook

Trigger when at least one is true:

1. TI provider reports React2Shell exploitation in the wild, public PoCs circulating and broad scanning/mass exploitation activity.
2. You operate internet-facing apps using:
 - React RSC versions 19.0.0–19.2.0 and/or unpatched Next.js versions, including certain 14.x canary, early 15.x and 16.x before fixed releases.
3. Internal telemetry shows:
 - abnormal POST requests to RSC endpoints (example endpoints called out for discovery: /react, /_flight, /_rsc)
 - suspicious request patterns: unexpected headers associated with RSC/Server Actions, obfuscated/high-entropy bodies, unusually large request sizes, spikes in 4xx/5xx/2xx around RSC endpoints and scanning.
 - evidence of server-side command execution (typical “proof-of-execution” commands are observed in the wild).
 - signs of post-exploitation such as payload downloads, credential harvesting (.env/env vars/metadata) or cryptomining deployment.

3. Scope Definition (What You Are Hunting For)

Assume the typical chain below (aligned with the feed’s attack vector and MITRE mapping).

Stage A: Recon/scanning for vulnerable RSC/Next.js endpoints

- internet-wide scanning and fingerprinting of RSC endpoints.

Stage B: Initial access and execution

- a crafted Flight protocol request triggers unsafe deserialization and unauthenticated RCE.

Stage C: Post-exploitation (tooling/payloads)

- downloaders, C2 frameworks, botnets/malware, cryptominers (example families mentioned include Sliver/Mirai variants/XMRig).

Stage D: Credential access and cloud pivot

- theft of .env secrets/env vars, cloud credentials via metadata service, lateral movement into adjacent workloads.

Stage E: Persistence/impact

- persistent shells/backdoors/cronjobs and/or cryptomining, service degradation, data theft.

4. Roles and Ownership

- Threat Intel / SOC Lead: confirms relevance, sets hunt objective, time window and crown-jewel app list.
- L2 Hunter: runs queries, builds timelines across WAF + app + cloud telemetry, validates signals.
- L3 / IR Lead: directs containment, forensics scope expansion, eradication decisions, rebuild/redeploy.
- App/DevOps: patch, rebuild/redeploy, SBOM/SCA validation, runtime hardening.
- Cloud/Platform: WAF rules, network restrictions, egress control, metadata protections, secret rotation process.
- Network/Security Engineering: detection uplift, alert tuning, dashboards, guardrails.

5. Inputs Required (Before You Start)

Collect these first:

1. Application inventory (critical)
 - list of internet-facing apps using Next.js App Router / RSC
 - SBOM/SCA output showing RSC-related packages and versions (feed explicitly recommends inventory via SCA/SBOM).
2. Version exposure
 - React RSC versions 19.0.0–19.2.0 (vulnerable) and patched target (19.2.1+).

- Next.js vulnerable ranges and patched target (16.0.7+).
3. Telemetry sources (minimum)
 - WAF / reverse proxy logs (Cloudflare/AWS ALB/WAF/Vercel/Fastly)
 - application logs (Next.js runtime logs, server logs)
 - container/runtime telemetry (Kubernetes audit logs, container stdout/stderr, EDR for hosts if applicable)
 - cloud logs (CloudTrail / Azure activity / GCP audit), IAM logs
 - DNS/proxy logs (egress)
 4. Known high-value targets
 - customer-facing portals
 - admin portals
 - internal tooling exposed to internet
 - CI/CD endpoints accessible from app runtime

6. Step-by-Step SOP (Start to End)

Step 1: TI Intake and Local Relevance Check

Objective: decide if relevant and define hunt window.

Actions:

1. Extract from TI:
 - severity and exploitation status (CVSS 10.0; active exploitation; PoCs circulating).
 - affected products/versions: React RSC 19.0.0–19.2.0; Next.js vulnerable lines and fixed versions.
 - endpoint patterns to inventory (/react, /_flight, /_rsc, internal RPC paths).
 - likely post-exploitation: credential harvesting, miners, C2 frameworks.
2. Determine local exposure:
 - which apps are internet-facing with RSC enabled
 - do you allow RSC endpoints publicly or behind access controls
 - what WAF controls exist today for RSC endpoints (body inspection/size limits/rate limits)

Output:

- Hunt window (recommended: from disclosure date to now, plus at least 30–90 days lookback due to mass scanning)
- Target list: internet-facing Next.js/RSC apps, prioritised by business criticality

Step 2: Build Target Application and Endpoint List (Asset Scoping)

Objective: reduce noise and hunt efficiently.

Actions:

1. Inventory via SBOM/SCA:
 - detect react-server and RSC protocol packages and their versions.
2. Confirm exposed RSC endpoints:
 - map publicly reachable RSC paths (/react, /_flight, /_rsc, dynamic internal RPC paths).
3. Prioritise:
 - production internet-facing apps
 - apps with broad permissions to internal APIs
 - apps with access to secrets (env vars, service tokens, DB credentials)

Output:

- “Hunt cohort” list: application, URL, environment, owner, RSC endpoint paths, versions, hosting model (container/serverless/edge), risk tier

Step 3: Hunt Track 1: Internet Recon and Exploit Attempt Detection (WAF/Proxy)

Objective: identify scanning and exploitation attempts at the edge.

What to hunt:

- spikes in POST requests targeting RSC endpoints
- unusual request sizes, high-entropy bodies, malformed content types
- suspicious RSC/Server Action related headers (feed highlights WAF detection focus around Flight payload characteristics and these header-like entities).
- elevated 4xx/5xx/2xx anomalies for those endpoints (2xx may indicate successful exploitation attempts)

Decision:

- If exploit attempt patterns exist for a specific app/endpoint, mark the app as “Suspect” and proceed to Track 2 and Track 3 immediately.

Step 4: Hunt Track 2: Server-Side Execution Signals (Next.js / Node Runtime)

Objective: validate whether exploit attempts led to server-side execution.

What to hunt (high signal):

- unexpected child process creation from Node/Next.js runtime (e.g., shell utilities being invoked)
- log lines indicating unexpected evaluation/execution errors
- “cheap math”/verification style patterns and basic system command outputs are commonly used by attackers to confirm RCE, per feed observations.
- file writes in runtime that should be immutable (new binaries/scripts in container filesystem, dropped tooling)

Decision:

- If there is evidence of command execution or abnormal child process spawning, treat as high-confidence compromise and proceed to containment while continuing evidence capture.

Step 5: Hunt Track 3: Credential Access and Secret Exposure (Cloud + App)

Objective: detect credential harvesting attempts enabled by RCE.

What to hunt:

- access to .env / environment variable dumps (application logs or container audit)
- outbound calls to cloud metadata service endpoints (AWS/Azure/GCP) as highlighted in the feed’s recommendations.
- unusual IAM activity following suspicious app events (new access keys, unusual STS assume-role, new policies attached)
- unusual reads from secret stores (Vault/Secrets Manager/KeyVault) from the impacted workload identity

Decision:

- If credential access is suspected, immediately initiate secret rotation workflow (Step 9) and widen scope to all services reachable with those credentials.

Step 6: Hunt Track 4: Payload Download, C2, Cryptomining (Egress + Host/Container)

Objective: identify post-exploitation tooling and impact.

What to hunt:

- unusual outbound traffic to rare domains/IPs shortly after suspicious RSC requests
- downloads of binaries/scripts to runtime
- CPU spikes / resource overuse patterns consistent with cryptomining (feed calls out XMRig and mining activity).
- indicators of C2 frameworks or botnet-like scanning from the compromised host

Decision:

- If C2/miner indicators exist, treat as active compromise and isolate workload.

Step 7: Containment (Immediate When High-Confidence Signals Found)

Containment goal: stop execution, prevent lateral movement, preserve evidence.

Actions (in order):

1. Edge containment:

- apply emergency WAF rules and rate limits for RSC endpoints (feed recommends WAF filtering and request-layer validation for exploit traffic patterns).
- restrict RSC endpoints to trusted networks where possible (VPN/Zero Trust/IP allowlists).

2. Workload containment:

- isolate the affected service (scale to zero / remove from load balancer / isolate namespace/security group)
- restrict outbound egress to only required domains/IPs (feed recommends limiting outbound traffic).

3. Evidence capture:

- WAF raw event samples (headers/body metadata, not payload contents)
- application logs around suspicious request timestamps
- container image digest currently running, runtime filesystem diff if possible
- cloud audit trails for the workload identity

Step 8: Eradication

Goal: remove attacker access and any persistence.

Actions:

1. Patch and rebuild:
 - upgrade React RSC to patched versions (19.2.1+) and align related dependencies (react-dom/next/internal RSC).
 - upgrade Next.js to fixed release (16.0.7+) and ensure transitive dependencies patched.
2. Rebuild and redeploy entire application stack:
 - rebuild containers/edge functions/serverless packages and deploy fresh artefacts (explicitly recommended).
3. Remove any unauthorised modifications:
 - check for tampered build output, modified server components, injected modules (feed calls this out as a concern).

Step 9: Credential and Access Hygiene (Mandatory in Cloud-Connected Apps)

Because the feed highlights env vars/.env exposure and cloud credential theft risk, assume secrets are compromised if RCE is confirmed or strongly suspected.

Actions:

1. Rotate immediately:
 - IAM access keys, DB credentials, OAuth/SSO secrets, JWT signing keys, third-party API keys.
2. Invalidate sessions and tokens:
 - revoke active sessions where feasible
3. Reduce blast radius:
 - move secrets out of environment variables into managed secret stores (feed recommends this).

Step 10: Recovery and Hardening

Goal: prevent recurrence, enforce defence-in-depth.

Implement controls aligned to the feed recommendations:

1. Reduce unnecessary exposure:

- remove public internet exposure for RSC endpoints; enforce VPN/Zero Trust/IP allowlists.

2. WAF and HTTP validation:

- detect/block anomalous POST to Flight endpoints, high-entropy bodies, suspicious Flight protocol fields and enforce content-type/size validation.

3. Host/runtime hardening:

- enforce read-only file systems for Node containers
- restrict child process execution where feasible
- limit outbound traffic (egress filtering)
- enable file integrity monitoring / immutable deployments.

4. Cloud credential protection:

- block direct access to metadata service endpoints from workloads where feasible and enforce least privilege.

Step 11: Reporting (What to Produce)

Deliverables:

1. Hunt report (one pager + appendix):

- TI summary and why relevant
- systems/apps reviewed (scope)
- findings (confirmed/suspicious/clean)
- evidence snapshots: WAF event samples, runtime logs, cloud audit events
- containment/eradication actions

2. Risk statement:

- unauthenticated RCE on internet-facing app, credential exposure risk, cloud pivot risk, potential data theft/mining impact.

3. Lessons learned:

- detection gaps at WAF layer, logging completeness gaps (body metadata, request IDs correlation), patch governance gaps

Step 12: Detection Engineering (Turn Hunt Into Permanent Detections)

Implement detections aligned to the feed's MITRE mapping and WAF guidance.

Edge/WAF detections:

- anomalous POST to /react, /_flight, /_rsc with unexpected content-type and high-entropy/obfuscated body patterns
- suspicious RSC/server action headers and malformed Flight payload characteristics

Runtime detections:

- Next.js/Node spawning shell utilities or unexpected child processes (Execution)
- downloads to runtime / new binaries (T1105 style activity)
- suspicious metadata service access from app (Credential Access)

Cloud detections:

- unusual IAM key creation/role assumption after app exploitation window
- secret-store access anomalies from the workload identity

7. End-to-End Worked Example With Simulated Logs (Training Timeline)

Scenario summary:

- Internet-facing Next.js app with RSC enabled receives exploit-like traffic to an RSC endpoint.
- WAF logs show anomalous POST requests (body metadata abnormal).
- App runtime shows unexpected child process execution attempts.
- Cloud logs show metadata probing and a suspicious IAM activity burst.
- SOC contains, rotates secrets, patches and rebuilds/redeploys.

This example uses placeholders and behavioural signals; it does not include exploit payload content.

A) WAF / Reverse Proxy Logs (Exploit Attempt Pattern)

timestamp	app	src_ip	method	uri	status	req_bytes	content_type
2026-02-19T03:12:11Z	PAY-PORTAL	198.51.100.23	POST	/_rsc	200	142880	application/octet-stream
							HIGH_ENTROPY_BODY,UNUSUAL_HEADER_SET
2026-02-19T03:12:18Z	PAY-PORTAL	198.51.100.23	POST	/_rsc	500	141992	application/octet-stream
							DESERIALIZATION_ERROR_PATTERN

2026-02-19T03:12:29Z PAY-PORTAL 198.51.100.88 POST /_flight 200 138211
application/octet-stream true SCAN_PATTERN,RETRY_BURST

Why high-signal:

- targeted RSC endpoints (inventory guidance in feed includes these paths).

B) Application Runtime Logs (Next.js / Node)

timestamp	pod	level	msg
2026-02-19T03:12:12Z	pay-portal-7c9	WARN	RSC request handler: unexpected serialized object shape; requestId=RSC-8f21
2026-02-19T03:12:13Z	pay-portal-7c9	ERROR	Unhandled exception in react-server deserialization; requestId=RSC-8f21
2026-02-19T03:12:14Z	pay-portal-7c9	ALERT	Child process execution attempt detected from node runtime; requestId=RSC-8f21

Why high-signal:

- feed highlights unsafe deserialization leading to server-side JS execution.

C) Container / Host Telemetry (Process and File)

timestamp	host/pod	event_type	details
2026-02-19T03:12:14Z	pay-portal-7c9	PROCESS_START	parent=node pid=2213 child=/bin/sh (unexpected)
2026-02-19T03:13:01Z	pay-portal-7c9	NET_CONNECT	dst=169.254.169.254:80 path=/latest/meta-data/ (blocked)
2026-02-19T03:13:30Z	pay-portal-7c9	FILE_WRITE	/tmp/.cache/.x (new file in runtime)

Why high-signal:

- feed recommends blocking metadata access and limiting child-process execution / outbound traffic.

D) Cloud Audit Logs (Credential Abuse After Exploitation Window)

timestamp	account	principal	action	result	note
2026-02-19T03:18:40Z	PROD	pay-portal-role	sts:AssumeRole	SUCCESS	unusual_destination_ip=198.51.100.23
2026-02-19T03:19:05Z	PROD	pay-portal-role	iam:CreateAccessKey	SUCCESS	unexpected_for_workload=true
2026-02-19T03:20:10Z	PROD	pay-portal-role	secretsmanager:GetSecretValue	SUCCESS	spike_count=47

Why high-signal:

- feed emphasises cloud credential harvesting and immediate secret rotation if compromise suspected.

8. Final Decision Logic (How Analyst Concludes)

If you have:

- exploit-attempt patterns targeting /react/_flight/_rsc plus
- runtime deserialization errors and/or unexpected child process attempts plus
- metadata probing and/or abnormal IAM/secret-store access plus
- evidence of payload download / cryptomining / persistent changes

Then outcome:

- Confirmed compromise (high confidence)
- Immediate containment at WAF and workload level
- Full rebuild and redeploy of stack
- Secret rotation and credential invalidation
- Detection rule deployment for RSC endpoint exploit patterns, runtime child-process anomalies, metadata probing and cloud credential abuse

Reynolds Ransomware

Izzmier Cybersecurity Solution

Threat Intelligence Advisory

Advisory ID: SOC-INT-2026-02-REYNOLDS

Severity: Critical

Category: Ransomware (BYOVD-Enabled)

Date Issued: February 2026

Threat Actor (Attribution): Currently Unattributed – Financially Motivated Ransomware Operators

1. Situation Overview

Reynolds Ransomware is an advanced ransomware strain leveraging Bring Your Own Vulnerable Driver (BYOVD) techniques to disable endpoint security before encryption.

The ransomware deploys a vulnerable kernel driver (402.sys) and creates a malicious service (NSecKrnl) to kill EDR/AV processes, enabling stealthy encryption operations.

Reynolds Ransomware

Unlike traditional ransomware, Reynolds demonstrates:

- Kernel-level tampering
- Privilege escalation via SeLoadDriverPrivilege
- Credential harvesting before encryption
- Restart Manager abuse to unlock files
- Structured ransomware branding ("RestoreYourFiles.txt")

2. Initial Access & Execution

Observed Behavior

- Executed from user temp path:

C:\Users\<USER>\AppData\Local\Temp_6bd8a0291b268d3....exe
- Additional renamed executions:
 - Desktop\program.exe
 - Desktop\software.exe

UPX-packed obfuscation detected (defense evasion).

MITRE Tactics Observed

- TA0001 – Initial Access
- TA0002 – Execution
- TA0004 – Privilege Escalation
- TA0005 – Defense Evasion
- TA0040 – Impact

3. Privilege Escalation & Driver Abuse (Critical)

BYOVD Technique

- Adjusts token privileges (SeLoadDriverPrivilege)
- Loads vulnerable driver:

C:\402.sys

- Creates service:

NSecKrnL

This driver is then used to terminate security processes including:

- MsMpEng.exe
- CSFalconService.exe
- aswEngSrv.exe
- ekrn.exe
- ccSvcHst.exe
- Sophos-related services

4. Pre-Encryption Activity

Anti-Analysis & Evasion

- Calls:
 - GetTickCount
 - IsDebuggerPresent
 - DeviceIoControl
- Loads Rstrtmgr.dll to identify and stop file-locking processes
- Enumerates running processes extensively

Discovery & Data Harvesting

- System discovery (registry hardware/OS keys)
- Storage enumeration via DeviceIoControl
- Browser data harvesting (DOMStorage, Bing-related keys)
- Windows Credential Manager access
- Credential file harvesting

Reynolds gathers intelligence before encryption, indicating possible double-extortion potential.

5. Persistence Mechanisms

- Registry Run Keys
- Startup folder modifications
- Driver service registration (402.sys)
- Ransom note placement across multiple paths:
 - C:\RestoreYourFiles.txt
 - C:\Volume Information\RestoreYourFiles.txt

Ransom note name:

RestoreYourFiles.txt

6. Encryption Behavior

File Impact

- Renames and encrypts thousands of files
- Appends extension:

 .locked

Examples:

- APPDATA.ini.locked
- .dotnet*.dotnetUserLevelCache.locked
- Desktop000.dat.locked

Original files deleted; encrypted versions retained.

7. Network Behavior

Outbound connections observed to:

- g[.]bing[.]com

- `www[.]bing[.]com`
- `res[.]public[.]onedcn[.]static[.]microsoft`

Ports:

- TCP 443
- UDP 853

Traffic blends with legitimate Windows system components (StartMenuExperienceHost, CBS client).

8. Required SOC Actions

Immediate (Within 24 Hours)

1. Hunt for:
 - 402.sys driver presence
 - NSecKrnL service
 - Files with .locked extension
2. Alert on:
 - Mass file rename events
 - Mass process termination
 - Suspicious driver load events
3. Enable Microsoft Vulnerable Driver Blocklist.
4. Enforce HVCI / Memory Integrity.
5. Isolate infected endpoints immediately.

Short-Term (Within 7 Days)

- Audit endpoints for SeLoadDriverPrivilege abuse.
- Review event logs for:
 - Event ID 7045 (Service creation)
 - Driver installation events
- Hunt for:
 - Rstrtmgr.dll loaded by uncommon process
 - Credential Manager access spikes
 - Startup folder file writes
- Verify backup integrity and restore capability.

Medium-Term Hardening

- Remove local admin from standard users
- Implement WDAC / AppLocker allow-listing
- Enable tamper protection for endpoint security

- Monitor for mass process kill attempts
- Enforce immutable, offline backups
- Separate backup credentials from domain authentication

9. Escalation Criteria

Escalate to Incident Response Lead immediately if:

- NSecKrnI service detected
- 402.sys driver present
- .locked extensions observed
- Ransom note RestoreYourFiles.txt discovered
- Mass termination of security agents
- Restart Manager abuse detected

10. Risk Assessment

Likelihood: High (Active ransomware operations)

Impact: Critical (Kernel-level security bypass + enterprise encryption)

Business Risk: Severe operational disruption and potential data loss

Reynolds represents a modern ransomware evolution combining:

- BYOVD
- Credential harvesting
- Defense evasion
- Process tampering
- Enterprise-scale encryption

PLAYBOOK 4: REYNOLDS RANSOMWARE (BYOVD DRIVER ABUSE, SECURITY TOOL TAMPERING, ENCRYPTION WITH .LOCKED, RANSOM NOTE RESTOREYOURFILES.TXT)

1. Purpose

This playbook describes, step-by-step, how a SOC performs an intelligence-driven threat hunt and IR-aligned response when a TI feed reports Reynolds Ransomware activity featuring:

- Pre-ransomware intrusion indicators (loaders from user-writable paths, suspicious privilege use, lateral movement patterns)
- BYOVD (Bring Your Own Vulnerable Driver) style protection bypass and security process tampering

- Driver/service creation for kernel driver loading (example artefacts include a driver named 402.sys and a service named NSecKrnl)
- Use of Restart Manager (Rstrtmgr.dll) and process enumeration to stop processes locking files prior to encryption
- Mass file encryption and renaming with an extension marker .locked
- Ransom note drops as C:\RestoreYourFiles.txt and additional locations

The playbook covers start-to-end actions:

- intake and scoping
- retrospective hunting and validation
- containment and eradication
- recovery and hardening
- reporting and detection uplift

2. When to Trigger This Playbook

Trigger when at least one is true:

1. TI provider reports Reynolds Ransomware campaigns leveraging vulnerable driver abuse and security tool tampering, with guidance to enable Microsoft's vulnerable driver block list and harden endpoint controls.
2. Any internal telemetry shows one or more high-confidence signals:
 - Execution of an unknown EXE from a user temp path resembling C:\Users\<user>\AppData\Local\Temp_<hash>.exe
 - Privilege adjustment associated with driver loading (e.g., SeLoadDriverPrivilege use / token privilege changes)
 - New driver/service creation with artefacts like 402.sys and service NSecKrnl
 - Unusual load of Rstrtmgr.dll by a non-standard process, followed by process kills or mass file access patterns
 - Presence of ransom note RestoreYourFiles.txt or rapid appearance of many files ending in .locked
3. You see mass encryption symptoms:
 - thousands of file rename/write events
 - abnormal I/O spikes on endpoints/servers
 - user reports "files cannot be opened" and ransom note present

3. Scope Definition (What You Are Hunting For)

From the TI feed, assume this typical chain:

Stage A: Initial execution from user-writable locations

- Sample executed from temp path and then copied/renamed into generic-looking binaries on Desktop (e.g., program.exe, software.exe)

Stage B: Anti-analysis and environment prep

- Sleep/timing checks, debugger checks, repeated process enumeration; Rstrtmgr.dll is loaded to identify/stop processes locking files

Stage C: BYOVD/driver-based security bypass and service manipulation

- Adjusts privileges (e.g., SeLoadDriverPrivilege) and loads a kernel driver (example path ??\402.sys), creates/starts service NSecKrn1

Stage D: Discovery and harvesting

- System and storage discovery; browser artefact discovery; credential access from Windows Credential Manager and files

Stage E: Pre-encryption process tampering

- Stops processes that lock files (Restart Manager usage; process kill patterns)

Stage F: Encryption and impact

- Mass rename/encrypt with .locked marker, deletes originals, drops RestoreYourFiles.txt in multiple paths

Stage G: Network behaviour (may blend with normal traffic)

- Outbound connections observed to Bing/Microsoft CDN domains (environment/connectivity checks or abuse of pre-existing components rather than explicit C2)

4. Roles and Ownership

- Threat Intel / SOC Lead: confirms relevance, sets hunt window, defines crown-jewel scope (core banking, payment, AD, backup, VDI, file servers).
- L2 Hunter: executes hunt tracks, builds timelines, identifies patient-zero and spread.
- L3 / IR Lead: containment decisions, rebuild criteria, credential rotation plan, business coordination.

- Endpoint Team: isolate hosts, acquire triage, redeploy images, enforce driver block controls.
- AD/IAM Team: account containment, privileged access review, token revocation, emergency access control.
- Backup Team: protect backups, check deletion/modification attempts, restore planning.
- Network Team: segmentation enforcement, egress containment if needed.
- Platform Team: SIEM detections, EDR policy tuning, allowlisting/ASR deployment.

5. Inputs Required (Before You Start)

Collect these first:

1. Asset inventory and criticality
 - endpoint list (workstations, servers)
 - crown-jewel servers (file servers, domain controllers, backup servers)
 - backup infrastructure and immutability status
2. Telemetry availability (minimum)
 - EDR process creation + module load + file events
 - Windows Security logs (4688 if enabled, 7045 service creation, registry auditing if available)
 - DNS/proxy logs
 - backup platform logs
 - AD authentication logs
3. TI behaviour and artefacts from the feed (examples)
 - driver/service artefacts: 402.sys and NSecKrnL
 - ransomware marker: .locked
 - ransom note: RestoreYourFiles.txt
 - Restart Manager usage: Rstrtmgr.dll by uncommon process
 - recommendation controls: enable Microsoft Vulnerable Driver Blocklist, HVCI/Memory Integrity, restrict driver installs, application allowlisting, monitor new kernel services/driver loads

6. Step-by-Step SOP (Start to End)

Step 1: TI Intake and Local Relevance Check

Objective: decide if relevant and define hunt window.

Actions:

1. Extract from TI:
 - key behaviours: BYOVD/driver abuse, security tampering, mass encryption with .locked, ransom note naming and paths
 - recommended controls: vulnerable driver blocklist, HVCI, restrict driver installs, allowlisting, monitor driver/service loads
2. Define hunt window:
 - If suspicious encryption seen: last 24–72 hours for impact, plus 14–30 days for intrusion phase.
 - If TI-only and no impact yet: last 30–90 days for early intrusion and driver/service events.

Output:

- Hunt window and priority scope list.

Step 2: Build Target Host Cohort (Asset Scoping)

Objective: reduce noise and focus where Reynolds is most likely to land/spread.

Actions:

1. Identify:
 - hosts with high privileges (IT admins, SOC workstations, jump servers)
 - file servers and shared drives
 - backup servers and management consoles
 - endpoints where users often download and run files (HR, finance operations)
2. Pull endpoint list that shows:
 - execution from %TEMP% and Desktop*.exe patterns described in TI
 - new service creation / driver loads

Output:

- Hunt cohort list (hostname, user, IP, OU, business unit, criticality).

Step 3: Hunt Track 1- Initial Execution (User Temp / Desktop Renamed Binaries)

Objective: find patient-zero and initial malware execution.

What to hunt:

- Process execution from:
 - C:\Users\<user>\AppData\Local\Temp_<hash>.exe pattern
 - C:\Users\<user>\Desktop\program.exe or software.exe-style renamed binaries
- Packed/obfuscated binaries (UPX-packed behaviour noted)

Decision:

- If found: mark endpoint as Suspect, pivot immediately to Track 2–4 on same host and any lateral movement from it.

Step 4: Hunt Track 2 - Anti-analysis and Process Enumeration (Rstrtmgr.dll)

Objective: confirm ransomware-like preparation and pre-encryption behaviour.

What to hunt:

- Uncommon process loading Rstrtmgr.dll
- Repeated process enumeration events that may precede targeted process termination

Decision:

- If Rstrtmgr.dll load + process enumeration observed on Suspect host, escalate severity; start containment planning while continuing evidence capture.

Step 5: Hunt Track 3 - Driver/Service Abuse (BYOVD-style)

Objective: detect attempts to disable security tooling or gain kernel-level capability.

What to hunt:

- Token privilege adjustments associated with driver loading (e.g., SeLoadDriverPrivilege)
- Registry/service image path indicating driver load:
 - service image path set to ??\402.sys (driver artefact)
- New service created: NSecKrnl
- Alerts for suspicious service creation, especially where driver loads from user-writable directories (recommended detection focus)

Decision:

- If driver/service creation is confirmed, treat as high-confidence compromise and proceed to containment immediately (Step 7).

Step 6: Hunt Track 4 - Credential and Data Harvesting

Objective: identify whether attacker has harvested credentials that enable lateral spread.

What to hunt:

- Access to Windows Credential Manager and credential files (“Credentials from Password Stores – Windows Credential Manager”, “Credentials in Files”, “Unsecured Credentials”)
- Browser artefact discovery and DOMStorage/registry access patterns described

Decision:

- If credential access suspected, immediately initiate credential rotation workflow (Step 9) and widen scope to hosts accessed using those accounts.

Step 7: Hunt Track 5 - Encryption and Impact Confirmation

Objective: confirm ransomware execution and quantify blast radius.

What to hunt:

- Mass file rename/write with .locked extension across:
 - C:\, %USERPROFILE%, %APPDATA%, %LOCALAPPDATA%
- Ransom note creation:
 - C:\RestoreYourFiles.txt and other locations like C:\Volume Information\RestoreYourFiles.txt

Decision:

- If .locked surge and ransom note present, declare ransomware event and execute containment at scale (Step 8) with business continuity coordination.

Step 8: Containment (Immediate When High-Confidence Signals Found)

Containment goal: stop encryption/spread, preserve evidence, protect backups.

Actions (in this order):

1. Isolate impacted endpoints via EDR network containment.
2. Contain identity:
 - disable or restrict suspected accounts used during the timeframe
 - block interactive logons for suspicious admin accounts
3. Protect backups immediately:
 - enforce immutability/offline posture
 - restrict backup admin access
 - alert for bulk deletion/modification attempts (recommended readiness control)
4. Block driver abuse vectors:
 - enable Microsoft Vulnerable Driver Blocklist and enforce HVCI/Memory Integrity (recommended controls)
5. Evidence capture:
 - EDR triage package (process tree, command line, hashes)
 - service creation logs (7045), registry evidence for driver service
 - sample of encrypted file paths, ransom note hashes/paths
 - list of processes terminated (if available)

Step 9: Eradication

Goal: remove malware, persistence and risky artefacts; restore trustworthy state.

Actions:

1. Remove persistence and driver/service artefacts after evidence capture:
 - disable/remove suspicious service NSecKrnL and remove associated driver artefacts like 402.sys
2. Remove dropped binaries from temp/desktop paths (initial execution paths described)
3. If ransomware executed and driver abuse occurred:
 - prefer rebuild/reimage of impacted endpoints/servers for high assurance in a banking environment

4. Validate that security tooling is functional (tamper protection, EDR/AV services running), as recommended hardening includes tamper protection and detection of process termination attempts

Step 10: Credential and Access Hygiene (Financial Sector Requirement)

Because the TI feed notes credential access behaviour and harvesting, treat impacted endpoints as credential exposure risk.

Actions:

1. Reset credentials:
 - affected users
 - local admin credentials used on impacted machines
2. Rotate:
 - privileged accounts used during the incident window
 - service accounts that logged on to impacted hosts
3. Invalidate sessions/tokens where feasible.
4. Review privileged group membership changes and anomalous logons during window.

Step 11: Recovery and Hardening

Goal: prevent recurrence and ensure resilience.

Controls to implement (aligned to TI recommendations):

1. BYOVD protection and driver governance:
 - enable Microsoft Vulnerable Driver Blocklist
 - enforce HVCI/Memory Integrity
 - prevent driver installs except approved
 - application allowlisting and monitoring for new kernel services/driver loads
2. Endpoint hardening:
 - tamper protection to prevent termination of security processes
 - alert on mass process termination attempts
 - monitor suspicious service creation for driver loads from user-writable directories

3. Pre-ransomware detection focus:

- investigate DLL sideloading/unknown loaders from Temp/ProgramData/user folders
- monitor abnormal credential use, privilege escalation, lateral movement
- alert on admin tool usage outside maintenance windows (PsExec/WMI/remote service creation)
- detect scheduled tasks/startup modifications and new admin accounts

4. Backup readiness:

- maintain offline/immutable backups separated from domain auth
- test restore procedures
- monitor for bulk deletion/modification
- store backup credentials separately

Step 12: Reporting and Detection Uplift

Deliverables:

1. Incident/hunt report:

- TI summary and relevance
- scope and endpoints reviewed
- patient-zero hypothesis and timeline
- evidence snapshots: driver/service creation, Rstrtmgr.dll load, .locked mass rename, ransom note paths
- containment and eradication actions
- restore status and residual risk

2. Detection engineering (permanent detections):

- New service creation: NSecKrnL and any service image paths pointing to ??*.sys driver artefacts (e.g., 402.sys)
- Uncommon process load of Rstrtmgr.dll (pre-encryption indicator)
- Execution from temp path hash-like filename patterns
- Mass rename/write to .locked extension and ransom note RestoreYourFiles.txt
- Token privilege adjustments consistent with driver loading (SeLoadDriverPrivilege)
- Backup deletion/modification attempts and unusual backup console logons

7. End-to-End Worked Example With Simulated Logs (Training Timeline)

Scenario Summary

- Workstation ABC-FIN-032 executes a suspicious EXE from temp.

- Privilege adjustment and driver service creation occurs (402.sys, NSecKrnI).
- RstrtMgr.dll is loaded, processes enumerated.
- Files are encrypted and renamed with .locked.
- Ransom note RestoreYourFiles.txt is dropped.
- SOC isolates host, protects backups, rotates credentials and rebuilds.

A) EDR Process Creation (Initial Execution)

timestamp	host	user	parent_process	process_name	cmdline
2026-02-20T01:11:08Z	ABC-FIN-032	ABC\amira	explorer.exe	_6bd8a0291b268d32422139387864f15924e1db05d.exe	"C:\Users\amira\AppData\Local\Temp_6bd8a0291b268d32422139387864f15924e1db05d.exe"
2026-02-20T01:11:24Z	ABC-FIN-032	ABC\amira	_6bd8a0....exe	program.exe	"C:\Users\amira\Desktop\program.exe"

B) Windows Service Creation (Driver/Kernel Service)

timestamp	host	event_id	service_name	image_path
2026-02-20T01:12:10Z	ABC-FIN-032	7045	NSecKrnI	\\?\C:\402.sys

C) EDR Module Load (Restart Manager)

timestamp	host	process_name	module_loaded
2026-02-20T01:12:44Z	ABC-FIN-032	program.exe	C:\Windows\System32\RstrtMgr.dll

D) EDR Behaviour (Process Enumeration and Tampering Attempt)

timestamp	host	process_name	event_type	detail
2026-02-20T01:13:02Z	ABC-FIN-032	program.exe	ENUM_PROCESSES	repeated=5
2026-02-20T01:13:10Z	ABC-FIN-032	program.exe	SECURITY_PROCESS_TARGET	target=MsMpEng.exe attempt=TERMINATE
2026-02-20T01:13:12Z	ABC-FIN-032	program.exe	SECURITY_PROCESS_TARGET	target=CSFalconService.exe attempt=TERMINATE

E) File Encryption Pattern (Mass Rename to .locked)

timestamp	host	process_name	event_type	file_path
2026-02-20T01:14:21Z	ABC-FIN-032	program.exe	FILE_RENAME	C:\Users\amira\Documents\budget.xlsx -> C:\Users\amira\Documents\budget.xlsx.locked
2026-02-20T01:14:22Z	ABC-FIN-032	program.exe	FILE_RENAME	C:\Users\amira\Desktop\OpsReport.docx ->

```

C:\Users\amira\Desktop\OpsReport.docx.locked
2026-02-20T01:14:23Z ABC-FIN-032 program.exe FILE_RENAME
C:\Users\amira\AppData\Local\mailcache.jrs ->
C:\Users\amira\AppData\Local\mailcache.jrs.locked
2026-02-20T01:14:24Z ABC-FIN-032 program.exe FILE_RENAME
C:\Users\amira\AppData\Roaming\Desktop000.dat ->
C:\Users\amira\AppData\Roaming\Desktop000.dat.locked

```

F) Ransom Note Creation

```

timestamp      host      process_name event_type  file_path
2026-02-20T01:15:02Z ABC-FIN-032 program.exe FILE_CREATE
C:\RestoreYourFiles.txt
2026-02-20T01:15:10Z ABC-FIN-032 program.exe FILE_CREATE C:\Volume
Information\RestoreYourFiles.txt

```

G) Proxy/DNS Logs (Blended Connectivity Traffic)

```

timestamp      host      process_name      dest_domain      dest_port proto
action
2026-02-20T01:16:01Z ABC-FIN-032 StartMenuExperienceHost.exe g.bing.com
443 TCP ALLOW
2026-02-20T01:16:09Z ABC-FIN-032 StartMenuExperienceHost.exe
res.public.onecdn.static.microsoft 443 TCP ALLOW
2026-02-20T01:16:22Z ABC-FIN-032 StartMenuExperienceHost.exe www.bing.com
853 UDP ALLOW

```

8. Final Decision Logic (How Analyst Concludes)

If you have:

- suspicious EXE executed from temp or renamed binaries on Desktop
- privilege adjustment consistent with driver loading and new service NSecKrnI with driver 402.sys
- uncommon RstrtMgr.dll load and process enumeration/tampering
- mass renames to .locked and ransom note RestoreYourFiles.txt

Then outcome:

- Confirmed ransomware (high confidence)
- Immediate containment at endpoint + identity + backup layers
- Credential rotation and rebuild for high assurance
- Detection pack rollout focusing on driver/service creation, Restart Manager use and encryption markers, plus the TI-recommended BYOVD protections

The Shadow Campaigns, a Global Espionage

Izzmier Cybersecurity Solution

Threat Intelligence Advisory

Advisory ID: SOC-INT-2026-02-SHADOW

Severity: High

Category: Cyber Espionage / Persistent Intrusion (Government & Critical Infrastructure)

Date Issued: February 2026

Threat Actor (Moderate Confidence): TGR-STA-1030 ("Shadow Campaigns") – State-aligned espionage actor

1. Situation Overview

A state-aligned cyber-espionage campaign tracked as TGR-STA-1030 (Shadow Campaigns) is actively targeting government and critical infrastructure globally, with confirmed compromises across 37+ countries and reconnaissance activity in 150+ nations.

The campaign prioritises long-term covert access for intelligence collection (policy, diplomacy, economic strategy, energy/telecom operations). Lack of outages or "loud" malware symptoms is expected.

A key differentiator is deployment of a custom Linux eBPF kernel rootkit ("ShadowGuard") to hide attacker activity at OS level, reducing visibility for traditional monitoring.

2. Attack Vector (Initial Access)

Primary initial access methods:

- Spearphishing delivering an initial loader (Diaoyu Loader)
- Exploitation of known (N-day) vulnerabilities in internet-facing enterprise systems:
 - email servers
 - VPN appliances
 - application servers

3. Targeting Profile

Targeted Sectors (High Relevance)

- Government ministries (Foreign Affairs, Interior, Finance, Trade/Economy, Immigration)
- Law enforcement / border control / counter-terrorism

- Critical infrastructure (energy, power generation, telecommunications)
- Government-linked financial institutions and regulators
- Public-sector IT services (e.g., visa/passport/citizen services)

Notable Regional Relevance: Malaysia is explicitly listed among targeted nations, with victims not disclosed.

4. Attack Chain Summary (MITRE-Driven)

Key techniques observed in the reported chain include:

- Reconnaissance: active scanning, victim identity/network info gathering (T1590, T1595, T1589)
- Initial Access: spearphishing attachment (T1566.001), exploit public-facing app (T1190)
- Execution: user execution (T1204.002)
- Defense Evasion: sandbox/virtualisation evasion, security software discovery (T1497, T1518.001)
- C2: ingress tool transfer + HTTPS C2 (T1105, T1071.001)
- Persistence: web shells (T1505.003), rootkit deployment (T1014)
- Credential Access: OS credential dumping (T1003)
- Lateral Movement: RDP/SSH remote services + tunnelling (T1021.001, T1572)
- Collection/Exfil: staging + exfil over C2 (T1074, T1041)
- Long-term Access: valid accounts (T1078)

5. Tools / Malware Observed

The report highlights use of:

- Diaoyu Loader (initial loader)
- ShadowPad (modular backdoor)
- ShadowGuard (Linux eBPF kernel rootkit)
- Cobalt Strike (post-exploitation)
- Web shells (e.g., Behinder, Godzilla)
- FRP (Fast Reverse Proxy) and neo-reGeorg (tunnelling/pivoting)
- Mimikatz (credential dumping)
- Custom reconnaissance/scanning scripts

6. What Defenders Will Observe (SOC Watchouts)

Expect subtle anomalies rather than major disruption:

Internet-facing services

- Unusual but valid-looking requests
- Legitimate URLs accessed in abnormal sequences
- Exploitation attempts shortly after patch release (N-day abuse)

Server/Endpoint behaviour

- Web services briefly spawning interpreters:
 - w3wp/nginx/apache spawning cmd or bash
- Small unfamiliar files on web servers (web shell indicators)
- Encoded scripting activity (including PowerShell indicators)

Network behaviour

- Outbound connections to rare external IPs over 443
- Periodic beaconing with consistent timing
- Encrypted tunnelling patterns
- SMB/SSH sessions between unrelated segments
- Slow, chunked data transfer during business hours

7. Required SOC Actions

Immediate (0–24 Hours)

1. Prioritise perimeter validation for:
 - Email servers, VPNs, public web apps, exposed portals
2. Hunt for web shells on internet-facing servers (recent file writes, unusual web root artifacts).
3. Increase monitoring for:
 - web server spawning cmd/bash
 - new outbound 443 to rare IPs
 - tunnelling indicators (FRP/neo-reGeorg-like patterns)
4. Audit authentication events:
 - logins at odd hours
 - server accounts initiating logins unexpectedly
 - lateral movement via SSH/RDP

Short-Term (24–72 Hours)

- Patch validation campaign for internet-facing systems (focus on recently disclosed vulns).
- Threat hunt for:
 - credential dumping indicators (T1003)
 - suspicious tunnelling (T1572)
 - staged archives and compressed transfers (T1074/T1041)

- Linux integrity checks on high-risk servers (rootkit risk):
 - unexpected eBPF activity
 - hidden processes/files mismatching userland tools (ShadowGuard behavior)

Medium-Term Hardening

- Enforce MFA for privileged and remote access
- Tighten egress filtering (restrict outbound from servers)
- Improve log coverage (web, auth, endpoint, network, Linux audit)
- Strengthen phishing controls (SPF/DKIM/DMARC, sandboxing, simulation)

8. Escalation Criteria

Escalate to IR Lead immediately if any of the following are confirmed:

- Web shell found on internet-facing server
- Evidence of credential dumping / Mimikatz indicators
- Repeated periodic beaconing to rotating infrastructure
- Protocol tunnelling indicators (FRP/neo-reGeorg)
- Signs of Linux kernel-level stealth/rootkit behaviour (eBPF hiding)

9. Risk Assessment

Likelihood: Moderate to High (global reconnaissance includes Malaysia)

Impact: High (strategic intelligence theft, long dwell time)

Business Risk: High for regulated sectors, critical services and public-sector-linked environments

PLAYBOOK 5: THE SHADOW CAMPAIGNS (TGR-STA-1030) – GLOBAL CYBER-ESPIONAGE WITH WEB SHELLS, MULTI-C2, TUNNELLING and LINUX EBPF ROOTKIT “SHADOWGUARD”

1. Purpose

This playbook describes, step-by-step, how a SOC performs an intelligence-driven threat hunt when a TI feed reports a state-aligned espionage campaign tracked as TGR-STA-1030 (Shadow Campaigns) targeting government and critical-infrastructure organisations worldwide, including activity in Malaysia. The campaign prioritises stealth and long-term intelligence collection, often leaving minimal “loud” alerts.

The playbook covers start-to-end actions:

- intake and scoping
- retrospective hunting and validation
- containment and eradication
- recovery and hardening
- reporting and detection uplift

2. When to Trigger This Playbook

Trigger when at least one is true:

1. TI reports active targeting of internet-facing enterprise systems (email, VPN, application servers) through:
 - spear-phishing delivering a loader (Diaoyu Loader)
 - exploitation of known vulnerabilities (N-day) on exposed systems
2. Internal telemetry shows one or more of these behaviours:
 - internet-facing servers spawning command interpreters (e.g., web service processes spawning cmd/bash)
 - small unfamiliar files on web roots consistent with web shells
 - outbound HTTPS beacons to rare external infrastructure, blending into normal traffic
 - internal tunnelling behaviour (encrypted tunnels, unusual proxying)
 - authentication events from systems that normally never initiate logins (lateral movement using stolen credentials)
3. You operate environments with:
 - exposed web apps, email systems, VPN appliances
 - Linux servers where kernel-level stealth is plausible (eBPF rootkit risk)

3. Scope Definition (What You Are Hunting For)

Assume the typical chain below (as described in the TI report):

Stage A: Reconnaissance and target mapping

- active scanning of exposed services and technology mapping

Stage B: Initial access

- spear-phishing (archive attachment) delivering Diaoyu Loader
- N-day exploitation of public-facing systems (email/VPN/app servers)

Stage C: Command and control + persistence

- inbound tool transfer (payload components from public repositories)
- outbound C2 over HTTPS
- web shells for re-entry
- Linux kernel eBPF rootkit ShadowGuard for stealth on Linux

Stage D: Credential access, discovery and lateral movement

- OS credential dumping
- account discovery and network service discovery
- remote services (RDP/SSH), tunnelling for internal pivoting

Stage E: Collection and exfiltration

- data staged and exfiltrated over encrypted channels, often low-and-slow

4. Roles and Ownership

- Threat Intel / SOC Lead: confirms relevance to your environment, sets hunt objective, time window, crown-jewel systems list.
- L2 Hunter: runs hunt tracks, builds timelines, validates signals, identifies patient-zero and pivot paths.
- L3 / IR Lead: containment decisions, forensics scope, eradication and rebuild requirements.
- Email/Endpoint Team: phishing triage, endpoint containment, EDR policy and artefact collection.
- Server/Linux Team: integrity validation, web server forensic collection, rootkit verification workflow.
- Network Team: egress controls, DNS/proxy blocks, tunnelling detection, segmentation.
- Platform/SIEM Team: correlation, rules, dashboards, log onboarding gaps closure.

5. Inputs Required (Before You Start)

Collect these first:

1. Target system inventory
 - internet-facing servers: email, VPN, web apps, exposed portals

- crown jewels: identity systems, regulatory reporting, sensitive finance/operations repositories
- Linux estate list and critical Linux servers

2. Telemetry availability (minimum)

- email gateway logs (attachment, sender domain novelty, URL clicks)
- web server logs (access, error, auth)
- EDR for servers where supported (process + file + network)
- Linux audit logs (auditd), syslog, auth logs
- DNS + proxy logs
- VPN logs
- IAM / AD authentication logs
- NDR/Zeek (if available) for tunnelling and unusual sessions

3. TI mapping

- key behaviours: phishing + N-day exploitation, multi-C2 + web shells, tunnelling, Linux eBPF rootkit stealth, low-noise persistence

6. Step-by-Step SOP (Start to End)

Step 1: TI Intake and Local Relevance Check

Objective: decide if relevant and define hunt window.

Actions:

1. Extract from TI:

- targeted sectors and motivations (espionage / intelligence collection)
- initial access methods (phish + public-facing exploitation)
- persistence methods (web shells, rootkit)
- post-compromise behaviours (tunnelling, credential dumping, low-and-slow exfiltration)

2. Determine local exposure:

- do you have internet-facing email/VPN/app servers?
- do you have Linux servers hosting critical services?
- do you have visibility for: web access logs, process telemetry on servers, outbound proxy/DNS?

Output:

- Hunt window (recommended: last 30–90 days + immediate last 7 days “hot window”)
- Target population list: all internet-facing systems + adjacent internal pivot candidates

Step 2: Build Target System List (Asset Scoping)

Objective: reduce noise and hunt efficiently.

Actions:

1. Create “Hunt Cohort” table:
 - system name, public IP, function (VPN/email/web portal), OS (Windows/Linux), owner, criticality
2. Prioritise:
 - systems with public exposure
 - systems with privileged access to internal networks
 - Linux servers hosting authentication, portals or integration services

Output:

- Hunt cohort list (hostname, IP, service, environment, risk tier)

Step 3: Hunt Track 1 - Spear-Phishing Intake (Email Gateway + Endpoint)

Objective: identify initial delivery via archive attachments and user execution.

What to hunt:

- archive attachments disguised as official documents
- “new sender domain” or rare sender patterns
- multiple recipients with government-themed lures
- endpoints executing extracted binaries shortly after email receipt

Decision:

- If malicious attachment delivery is confirmed, move affected users/endpoints to Suspect list and pivot to Track 4 (credential access) and Track 6 (lateral movement) immediately.

Step 4: Hunt Track 2 - Public-Facing Exploitation Signals (VPN/Email/App Servers)

Objective: detect N-day exploitation on exposed enterprise services.

What to hunt:

- abnormal sequences of legitimate URLs
- exploitation patterns shortly after patch disclosures (N-day abuse)
- web service processes spawning command interpreters (cmd/bash)
- creation of small unfamiliar files in web directories

Decision:

- If web process spawn or suspicious file creation is found, treat as high-confidence server compromise and proceed to containment actions (Step 9) while continuing evidence capture.

Step 5: Hunt Track 3 - Web Shell Detection (Persistence on Servers)

Objective: identify stealthy server-side persistence.

What to hunt:

- small new files in web roots or upload directories
- repeated POST requests to suspicious paths with similar sizes/timing
- unusual user-agent strings
- web shell behaviour: commands triggered via HTTP parameters, anomalous 200 responses on “weird” URLs

Decision:

- If web shell is confirmed, isolate affected server and begin credential rotation planning (Step 11).

Step 6: Hunt Track 4 - Credential Access + Discovery (Windows and Linux)

Objective: detect expansion preparation.

What to hunt:

- OS credential dumping signals (EDR alerts, suspicious LSASS access on Windows, credential file access patterns)
- account discovery commands and group enumeration
- network service discovery activity toward file servers/DCs/databases

Decision:

- If credential access is suspected, widen scope to all systems accessed by those credentials in the window and fast-track credential hygiene (Step 11).

Step 7: Hunt Track 5 - Lateral Movement + Tunnelling

Objective: detect internal pivoting behaviour consistent with espionage.

What to hunt:

- SSH/RDP sessions between unrelated segments
- authentication originating from servers that typically never initiate logins
- long-lived encrypted tunnels, reverse proxies or SOCKS-style pivoting indicators
- new inbound admin sessions at odd hours

Decision:

- If tunnelling is observed, assume the actor is maintaining covert access; contain at network layer and expand hunt to adjacent internal segments.

Step 8: Hunt Track 6 - Linux eBPF Rootkit “ShadowGuard” Integrity Validation

Objective: validate whether Linux hosts are hiding attacker activity at kernel level.

What to hunt (defender-visible indicators):

- inconsistencies between process listings and observed network connections
- “impossible” gaps: network sessions with no owning process, missing binaries referenced by logs
- periodic outbound beacons from Linux servers with no corresponding service logs
- unexpected kernel module/eBPF artefacts or abnormal kernel behaviour

Practical validation workflow:

- collect immutable triage from Linux host:
 - /var/log/auth.log or equivalent, syslog/journal excerpts
 - auditd events for execve and file writes
 - netflow/Zeek for egress mapping
- compare:
 - known service baseline vs current running state
 - file integrity for critical binaries and service units
- if rootkit is suspected:
 - escalate to L3/forensics; plan for trusted boot/offline analysis and rebuild decision

Decision:

- If integrity cannot be trusted, treat as high-severity compromise and proceed to rebuild/redeploy for high assurance.

7. Containment, Eradication, Recovery

Step 9: Containment (Immediate When High-Confidence Signals Found)

Containment goal: stop attacker access, prevent lateral movement, preserve evidence.

Actions (in order):

1. Isolate impacted servers (EDR containment or network segmentation); do not reboot Linux suspected of kernel-level stealth until evidence guidance is followed.
2. Block C2 and tunnelling at egress:
 - proxy/DNS/firewall blocks for discovered rare destinations
 - restrict outbound from server subnets to only required destinations
3. Disable exposed entry points:
 - temporarily restrict public access to affected portals if feasible
 - apply WAF rules for suspicious requests
4. Evidence capture:
 - web logs, process trees, file hashes, suspicious files (web shells)
 - auth logs and VPN logs
 - Linux triage bundle for integrity analysis

Step 10: Eradication

Goal: remove persistence and close the exploited paths.

Actions:

1. Remove confirmed persistence:
 - web shell removal after evidence capture
 - remove unauthorised accounts/SSH keys/cron jobs
2. Patch exploited systems:
 - apply vendor fixes for the exploited public-facing vulnerability class

- ensure exposed services are fully updated and hardened
3. If rootkit suspected on Linux:
 - rebuild is strongly recommended (espionage-grade stealth + long dwell time risk)

Step 11: Credential and Access Hygiene (Mandatory)

Because the campaign focuses on long-term covert access, treat any compromised server as credential exposure risk.

Actions:

- reset credentials used on affected systems (service accounts, admins, VPN accounts)
- rotate secrets (API keys, certificates, tokens)
- invalidate sessions where feasible
- review privileged group changes and new accounts created in the window
- implement MFA/stronger controls for admin access paths (VPN, privileged portals)

Step 12: Recovery and Hardening

Goal: prevent recurrence of the same campaign patterns.

Hardening priorities (aligned to TI recommendations):

1. Strengthen email and phishing resilience:
 - advanced attachment filtering, DMARC/DKIM/SPF
 - targeted awareness and simulation for spear-phishing patterns
2. Patch and vulnerability management:
 - aggressive patching for internet-facing servers
 - asset inventory + vulnerability scanning
 - virtual patching/compensating controls for legacy systems
3. Server hardening and monitoring:
 - EDR coverage on servers where possible
 - application allowlisting for server workloads
 - least privilege and restricted admin pathways
4. Network monitoring and analytics:

- monitor outbound anomalies and tunnelling
- alert on SSH/RDP between unrelated systems
- SIEM correlation across endpoints, servers, network devices

8. Reporting and Detection Uplift

Step 13: Reporting (What to Produce)

Deliverables:

- Hunt report:
 - TI summary and relevance to your environment
 - scope (systems/users reviewed)
 - findings (confirmed/suspicious/clean) with evidence
 - containment and eradication actions taken
 - residual risk assessment (espionage = stealth + persistence)
- Executive risk narrative:
 - long-term intelligence collection risk, silent exfiltration, strategic data exposure

Step 14: Detection Engineering (Turn Hunt Into Permanent Detections)

Create/modify detections and dashboards:

Email:

- archive attachment delivery + first-seen sender domain + user execution correlation

Public-facing exploitation:

- web service process spawning command interpreter
- suspicious request sequences and abnormal auth patterns
- creation of small unfamiliar files (web shell candidates)

C2 and tunnelling:

- periodic beaconing patterns (consistent intervals, small encrypted bursts)
- protocol tunnelling indicators and long-lived sessions
- outbound connections from servers to rare external IPs over 443

Lateral movement:

- SSH/RDP between unrelated segments
- authentication initiated from servers that typically do not perform interactive logons

Linux integrity:

- host/process/network inconsistencies indicating stealth
- unexpected privileged changes on Linux critical servers

9. End-to-End Worked Example With Simulated Logs (Training Timeline)

Scenario summary

- A public-facing application server is exploited (N-day pattern), a web shell is planted, credentials are used for SSH pivoting and low-and-slow exfiltration begins.

A) WAF / Web Server Access Logs (Initial Exploit-Like Behaviour)

timestamp	src_ip	host	method	uri	status	bytes	user_agent
2026-02-08T02:14:11Z	198.51.100.44	ABC-public-portal	GET	/owa/	200	3812	Mozilla/5.0
2026-02-08T02:14:19Z	198.51.100.44	ABC-public-portal	POST	/portal/api/auth	200	912	Mozilla/5.0
2026-02-08T02:14:33Z	198.51.100.44	ABC-public-portal	GET	/portal/assets/	200	1290	Mozilla/5.0
2026-02-08T02:14:52Z	198.51.100.44	ABC-public-portal	POST	/portal/upload	200	488	Mozilla/5.0

B) Server Process Telemetry (Web Service Spawns Command Interpreter)

timestamp	host	parent_process	process	cmdline
2026-02-08T02:15:01Z	ABC-public-portal	w3wp.exe	cmd.exe	/c whoami
2026-02-08T02:15:06Z	ABC-public-portal	w3wp.exe	cmd.exe	/c ipconfig /all

C) File Integrity / EDR File Events (Web Shell Drop)

timestamp	host	event_type	file_path
2026-02-08T02:15:20Z	ABC-public-portal	FILE_CREATE	C:\inetpub\wwwroot\portal\assets\img\cache.aspx
2026-02-08T02:15:24Z	ABC-public-portal	FILE_WRITE	C:\inetpub\wwwroot\portal\assets\img\cache.aspx

D) Authentication Logs (Abnormal Server-Originating Logon)

timestamp	source_host	target_host	user	logon_type	result
2026-02-08T03:02:10Z	ABC-public-portal	ABC-app-02	ABC\svc_ops	3	SUCCESS

2026-02-08T03:05:44Z ABC-public-portal ABC-db-01 ABC\svc_ops 3
SUCCESS

E) Linux Auth Logs (SSH Pivot Between Unrelated Segments)

timestamp	host	event
2026-02-08T03:14:12Z	ABC-app-02	sshd[22144]: Accepted password for svc_ops from 10.10.5.21 port 51422
2026-02-08T03:16:40Z	ABC-app-02	sshd[22201]: Accepted password for svc_ops from 10.10.5.21 port 51490

F) Proxy / Netflow (Low-and-Slow Exfiltration Pattern)

timestamp	src_host	dest_ip	dest_port	proto	bytes_out	bytes_in	notes
2026-02-08T04:21:02Z	ABC-app-02	203.0.113.77	443	TCP	18422	6621	small_periodic
2026-02-08T04:31:02Z	ABC-app-02	203.0.113.77	443	TCP	18311	6554	small_periodic
2026-02-08T04:41:02Z	ABC-app-02	203.0.113.77	443	TCP	18509	6619	small_periodic

How the analyst concludes:

- public-facing service spawned command interpreter
- web shell file creation in web root
- server-originating auth to internal systems
- SSH pivot patterns
- periodic outbound encrypted beacons consistent with covert access and staged exfiltration (espionage pattern)

10. Final Decision Logic

If you have:

- public-facing exploitation indicators plus
- web shell persistence signals plus
- abnormal authentication/lateral movement (server-origin logons, SSH/RDP between unrelated segments) plus
- beaconing/tunnelling/exfil patterns consistent with low-noise espionage

Then outcome:

- Confirmed compromise (high confidence)

- Immediate containment, credential rotation and rebuild decisions (especially if Linux integrity is questionable)
- Detection uplift focused on web shell creation, server process spawning, tunnelling and abnormal authentication patterns